THE EXECUTIVE'S GUIDE TO

GLOBAL AI GOVERNANCE

Board-Level Decisions Under the EU, US, and Korean Regimes



WOONGSIK SU

FIRST EDITION · 2026

THE EXECUTIVE'S GUIDE TO

Global AI Governance

Board-Level Decisions Under the EU, US, and Korean Regimes

WOONGSIK SU

FIRST EDITION · 2026

FRONT MATTER

Copyright and Legal Disclaimer

The Executive's Guide to Global AI Governance: Board-Level Decisions Under the EU, US, and Korean Regimes. First Edition. © 2026 Woongsik Su. All rights reserved. No part of this publication may be reproduced, distributed, or transmitted in any form or by any means without the prior written permission of the author, except for brief quotations in critical reviews and other noncommercial uses permitted by copyright law.

Legal disclaimer. This publication is provided for informational and educational purposes only and does not constitute legal, regulatory, compliance, financial, or professional advice. Artificial intelligence governance is a rapidly evolving field: laws, regulatory guidance, and enforcement practices change over time and vary significantly across jurisdictions. The frameworks, thresholds, and decision rules presented here are reference implementations and starting points for analysis; they must be adapted, validated, and approved against the specific risk profile, industry requirements, and legal obligations of each organization. Readers should obtain advice from qualified legal counsel before acting on any matter described in this book. The author and publisher disclaim all liability for any loss, damage, or legal consequence arising directly or indirectly from the use of, or reliance on, the information contained in this publication.

FRONT MATTER

Table of Contents

About the Author 4

How to Use This Book 5

The Framework at a Glance: Know, Own, Control, Prove 7

PART I — The Executive's Problem 8

1 Why AI Governance Is Now a Board Issue 9

2 The Governance Framework: Know, Own, Control, Prove 16

3 Where Accountability Sits 21

PART II — The Three Regimes 25

4 The EU AI Act After the Omnibus 26

5 The GDPR Applied to AI 30

6 The United States I: Enforcement Without a Federal AI Act 33

7 The United States II: The State Layer in Motion 36

8 Korea: The AI Basic Act and PIPA 39

9 One Program, Three Regimes 42

PART III — Building the Function 46

10 The Business Case and Governance ROI 47

11 Organizational Design 50

12 The Twelve-Month Roadmap 52

13 Vendors and Third-Party AI 55

PART IV — Decisions 58

14 Three Decisions You Will Face 59

15 The Board Agenda 62

APPENDICES 65

A The Three Regimes at a Glance 66

B The Implementation Checklist 67

FRONT MATTER

About the Author

Woongsik Su is a PhD chemical engineer (Dr.-Ing., Saarland University, Germany) who has spent more than fifteen years working at the seam this book is written about: the place where advanced technology meets enterprise decision-making. He currently leads industry-process consulting at **BIOVIA, Dassault Systèmes**, in Seoul, where he serves as the primary technical contact translating customer R&D and commercial requirements into scientific software and AI/ML workflows for enterprises across the chemical and pharmaceutical sectors — the deployer's seat, where the governance questions in this book stop being abstract.

Before BIOVIA, as Digital Operational Manager at **Solvay** in Lyon and Seoul, he led global digital-enablement programs spanning robotics, IoT, and AI for materials and battery R&D — building a fully integrated robotic platform for battery-electrolyte formulation and machine-learning pipelines (Python, TensorFlow, Google BigQuery) that projected battery-experiment outcomes from materials data. Earlier roles took him through advanced process control at **SABIC SK Nexlene**, consulting leadership at Brand Institute with major pharmaceutical clients, and engineering positions in Germany. His doctoral research pioneered high-throughput experimentation for the discovery of selective oxidation catalysts — an early exercise in the data-driven, automated science that today's AI systems have industrialized.

The perspective of this book — governance argued from deployment experience rather than from the policy gallery — reflects that career. So does its three-regime scope: the author studied and worked in Germany for over a decade and in France, holds an **MBA** and an **LL.M. certificate** from Saarland University alongside his engineering doctorate, and completed **NVIDIA Deep Learning Institute** training including language- and vision-AI project work — a combination of legal, business, and hands-on AI grounding that maps directly onto the law-meets-engineering terrain of AI governance. He has led and mentored technical teams across Europe and Asia, works in English, German, and Korean, and lives in Seoul.

Connect with the author at **linkedin.com/in/suwoongsik**.

FRONT MATTER

How to Use This Book

This is a short book by design. It is written for the people who will be held accountable for artificial intelligence inside an organization — board directors, chief executives, and the senior leaders to whom they delegate — and it respects the single scarcest resource those people have: attention. Everything in the following fifteen chapters is organized around decisions you will actually face, not around the taxonomy of the underlying law. Where a legal regime is described, it is described so that you can allocate ownership, budget, and oversight; the statutory detail your counsel needs lives in the primary sources cited at the end of every chapter.

The book makes three structural commitments. First, it is anchored in the three regulatory regimes that matter most to a global enterprise today: the European Union's layered digital rulebook, headed by the AI Act and the GDPR; the United States' enforcement-driven patchwork of federal agency action and state statutes; and the Republic of Korea's AI Basic Act, which took effect in January 2026 as the world's second comprehensive horizontal AI regime. Second, it is organized by a single executive framework — **Know, Own, Control, Prove** — introduced in Chapter 2 and applied in every chapter thereafter, so that each new obligation you encounter has a known landing zone in your organization. Third, it treats facts with the discipline that board material demands: every chapter closes with a **Sources and Verification** section listing the primary instruments and named research behind its factual claims, verified as of August 2026, and the text never blends measured statistics with planning assumptions without saying which is which.

How the book is organized

PART	CHAPTERS	COVERAGE
I — The Executive's Problem	1–3	Why AI governance became a board issue; the Know-Own-Control-Prove framework; where legal accountability sits
II — The Three Regimes	4–9	The EU AI Act after the 2026 Digital Omnibus; the GDPR applied to AI; US federal enforcement; US state law; Korea's AI Basic Act and PIPA; one program under three regimes
III — Building the Function	10–13	The business case; organizational design; the twelve-month roadmap; third-party AI risk
IV — Decisions	14–15	Three recurring executive decisions; the standing board agenda
Appendices	A–B	EU/US/Korea comparison table; implementation checklist

Callout key

Four recurring callouts appear throughout the book:

BOARD QUESTION

The single question a director should ask management about the topic at hand.

KEY TAKEAWAY

A compressed summary of a chapter or section, designed for quick review.

COMMON FAILURE PATTERN

The specific implementation mistake that produces most regulatory findings in a given area: the failure to design out before it appears.

COST OF INACTION

What the documented enforcement record and named research say inaction has cost comparable organizations.

Currency

Coverage is current through **August 2026**, including Regulation (EU) 2026/1744 — the Digital Omnibus on AI — which entered into force in July 2026 and re-set the compliance calendar for high-risk AI systems in the European Union, and Korea’s AI Basic Act (Act No. 20676) and its Enforcement Decree, in force since January 22, 2026. Fine amounts, deadlines, and effective dates reflect the operative texts as of that point. Because the field moves quickly, verify the operative text before relying on any date or figure; the citations in each chapter exist to enable exactly that verification.

FRONT MATTER

The Framework at a Glance: Know, Own, Control, Prove

One framework runs through all fifteen chapters. It compresses the entire discipline of AI governance into four executive commitments, each expressed as a verb, because governance that cannot be stated as an action with an owner is not governance — it is aspiration.

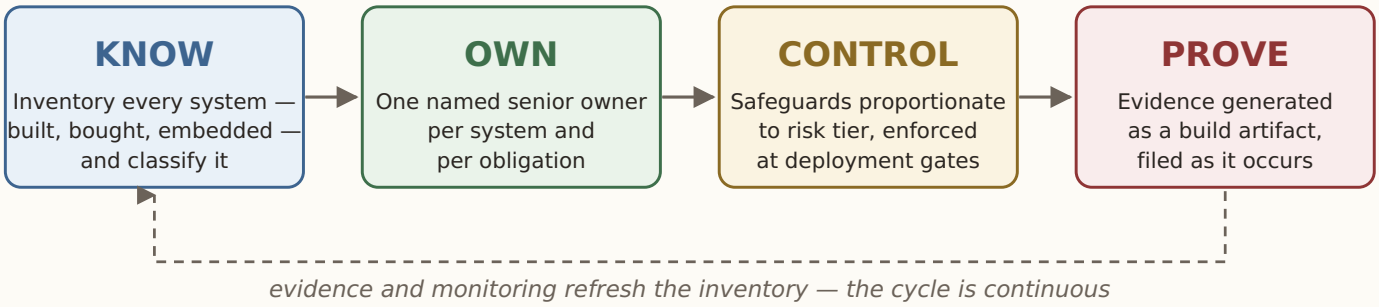


Figure 0.1. The Know–Own–Control–Prove cycle. Each commitment produces a defined output; the evidence layer feeds back into the inventory, making governance continuous rather than annual.

COMMITMENT	THE DEMAND	THE OUTPUT
KNOW	Maintain a complete, current inventory of every AI system the organization builds, buys, or embeds, classified by legal risk tier and business criticality. You cannot govern what you have not counted.	A single, refreshed system register
OWN	Assign a named senior owner to every system and every obligation. Committees advise; individuals own. Regulators, courts, and plaintiffs will look for the accountable person, and so should you.	A written accountability map
CONTROL	Apply controls proportionate to the risk tier: human oversight, testing before deployment, monitoring in production, and defined gates that a system must pass before it reaches customers, employees, or regulators.	Enforced deployment gates
PROVE	Generate the evidence as you go — documentation, assessment records, testing results, decision logs — so that when a regulator, auditor, customer, or court asks, the answer already exists. Evidence produced after the question arrives is remediation, not governance.	A standing evidence layer

The four commitments are sequential in logic and simultaneous in practice: an inventory without owners decays, owners without controls preside over risk, and controls without evidence cannot be demonstrated to anyone who matters. Chapter 2 develops the framework in full; every subsequent chapter maps its subject onto it.

PART I

THE EXECUTIVE'S PROBLEM

Why AI governance became a board issue, the framework that organizes the response, and where accountability actually sits.

CHAPTER 1

Why AI Governance Is Now a Board Issue

The decision this chapter supports. Whether to treat AI governance as a compliance line item delegated downward, or as a standing item of board-level risk oversight with dedicated ownership and budget. The evidence assembled here supports the second answer.

In this chapter. The enforcement record that moved AI from a technology question to a governance question; the two-sided regulatory reality (new AI-specific law layered on old law that already applies); the asymmetry between the cost of proactive governance and the cost of the documented failures; and the affirmative business case that has emerged alongside the defensive one.

1.1 The enforcement record is no longer hypothetical

For most of the last decade, AI risk was discussed in the conditional tense: what could go wrong, what a regulator might one day do. That era is over. The record that now exists is a record of completed enforcement actions, court rulings, settlements, and resignations, and it spans every category of consequence a board is charged with overseeing — financial, legal, operational, and reputational.

Consider what the documented record already contains. In the United States, the Equal Employment Opportunity Commission settled its first AI-related hiring discrimination case in 2023: **iTutorGroup** agreed to pay **$365,000** after the agency alleged that its application software automatically rejected female applicants aged 55 and older and male applicants aged 60 and older. The dollar figure was modest; the precedent was not. It established that an algorithm's screening decision is the employer's screening decision, and that intent is not required for liability. The point was reinforced when a federal court in California allowed *Mobley v. Workday* to proceed — a discrimination action against a software vendor whose AI screening tools were alleged to disadvantage applicants on the basis of age, race, and disability. The court's willingness to treat an AI vendor as potentially liable in the hiring chain redrew the risk map for every company that buys, rather than builds, its AI.

Financial regulators have moved as well. In October 2024, the Consumer Financial Protection Bureau ordered **Apple and Goldman Sachs** to pay a combined sum exceeding **$89 million** in penalties and consumer redress over failures in the Apple Card program, including dispute-handling breakdowns rooted in the automated systems that processed customer interactions. The same program had earlier been investigated by the New York State Department of Financial Services after public allegations of gender bias in credit limits; the regulator found no unlawful discrimination under fair lending law, but its report faulted the program's transparency and customer service — a reminder that an algorithm can survive a bias inquiry and still generate an enforcement file. Meanwhile the Securities and Exchange Commission opened a new front in 2024 with its first **"AI washing"** actions, charging two investment advisers — Delphia and Global Predictions — with making false and misleading statements about their use of AI, and collecting **$400,000** in combined civil penalties. The message to public-company boards was unambiguous: statements about AI capability are now securities statements.

In Europe, the enforcement machinery predates the AI Act, because the GDPR already reaches most of what AI systems do with personal data. The Irish Data Protection Commission's **€1.2 billion** fine against **Meta** in May 2023 — the largest GDPR fine on record, concerning unlawful transfers of European user data to the United States — demonstrated the scale the regime can reach. AI-specific applications followed: the Italian data protection authority, the Garante, temporarily banned ChatGPT in 2023 pending privacy remediations and in December 2024 fined **OpenAI €15 million** over the legal basis and transparency of its data processing. Biometric AI has proven especially costly: **Clearview AI**, which scraped billions of facial images to build a recognition database, has accumulated multi-million-euro fines across European authorities and agreed to a settlement valued at roughly **$50 million** in United States litigation under Illinois's Biometric Information Privacy Act.

Korea's enforcement history is shorter but pointed, and it arrived early. In April 2021, the Personal Information Protection Commission fined **Scatter Lab**, developer of the conversational chatbot **"Lee Luda" (Iruda)**, **103.3 million won** for building the service on private KakaoTalk messages collected through its earlier apps for a different purpose — the country's first sanction against an AI service for personal-data misuse — and its corrective orders reached the unlawfully processed data itself, not merely the balance sheet. The case fixed the PIPC's posture years before Korea's AI Basic Act existed: training data is regulated data, remedies can reach the model, and a consumer backlash can end a product faster than any regulator. The service was withdrawn within weeks of launch.

The record extends beyond fines to the failures that end careers and governments. The **Dutch childcare benefits scandal** — in which an algorithmic risk-scoring system used by the tax administration wrongly accused thousands of families, disproportionately those with dual nationality, of fraud — contributed to the resignation of the entire Dutch cabinet in January 2021 and remains the canonical demonstration that algorithmic harm scales administratively: one flawed model, applied uniformly, manufactures injustice at a volume no human process could match. In the United States, the documented wrongful arrests of Robert Williams and Porcha Woodruff in Detroit, both driven by erroneous facial recognition matches, put faces on the same lesson.

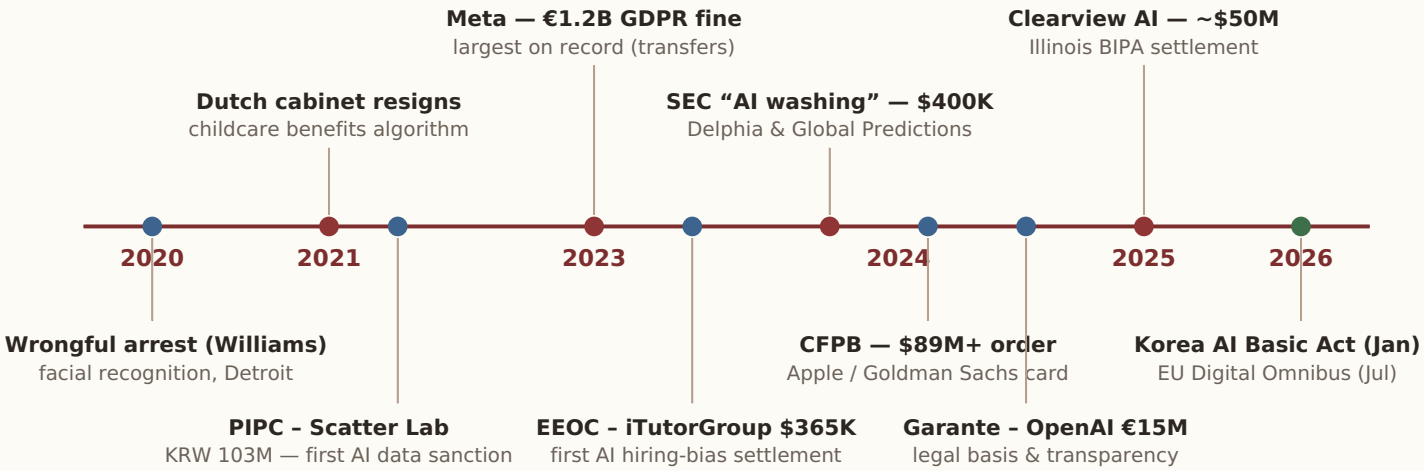


Figure 1.1. Selected documented AI enforcement actions and regulatory milestones, 2020–2026. Every enforcement action shown was brought under law that predates any AI-specific statute; the 2026 milestones mark the arrival of the comprehensive AI regimes.

BOARD QUESTION

Which of our deployed AI systems, if it failed the way the systems in this section failed, would produce a regulatory action, a lawsuit, or a headline — and who in this organization owns that system today?

1.2 Two-sided regulation: new law layered on old law

Executives sometimes draw comfort from the observation that AI-specific statutes are new and, in places, delayed. The comfort is misplaced, because AI regulation is two-sided. On one side stand the new horizontal regimes — the EU AI Act chief among them — which arrive on published timetables and can be planned for. On the other side stands the entire

existing body of law, which already applies to AI systems today and always has: data protection law, consumer protection law, anti-discrimination law, financial services regulation, product liability, and securities law. **Every enforcement action described in the previous section was brought under old law. Not one required an AI act.**

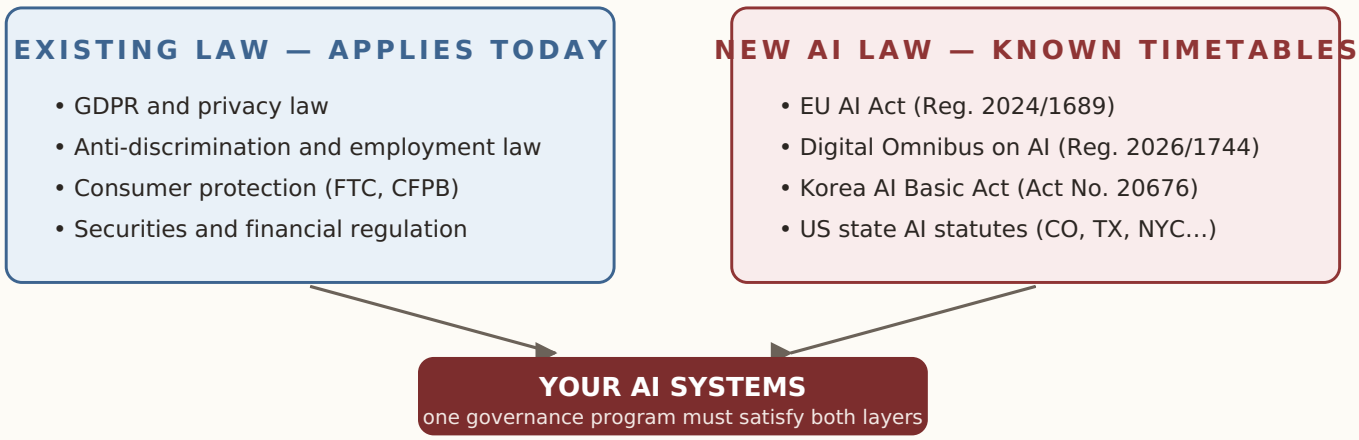


Figure 1.2. Two-sided regulation. Enforcement to date has come entirely from the left layer; the right layer adds obligations on published dates. Governance must be designed against both simultaneously.

The new layer is nonetheless consequential, and its calendar has just been redrawn. The EU AI Act — Regulation (EU) 2024/1689, the world's first comprehensive horizontal AI statute — entered into force in August 2024 with staggered application: prohibitions on certain practices from February 2025, obligations for general-purpose AI model providers from August 2025, and the demanding high-risk regime originally scheduled for August 2026. In July 2026, the **Digital Omnibus on AI (Regulation (EU) 2026/1744)** deferred the high-risk obligations — to **December 2, 2027** for standalone Annex III systems and to **August 2, 2028** for AI embedded in products already covered by EU product-safety law — while leaving the prohibitions, the general-purpose AI obligations, and the Article 50 transparency and AI-content-labeling duties on their original dates. Chapter 4 treats the details. What matters at board level is the shape of the situation: the deferral bought implementation time, not exemption, and the penalty ceiling that awaits — up to **€35 million or 7 percent of global annual turnover** for prohibited practices — sits above even the GDPR's 4 percent maximum.

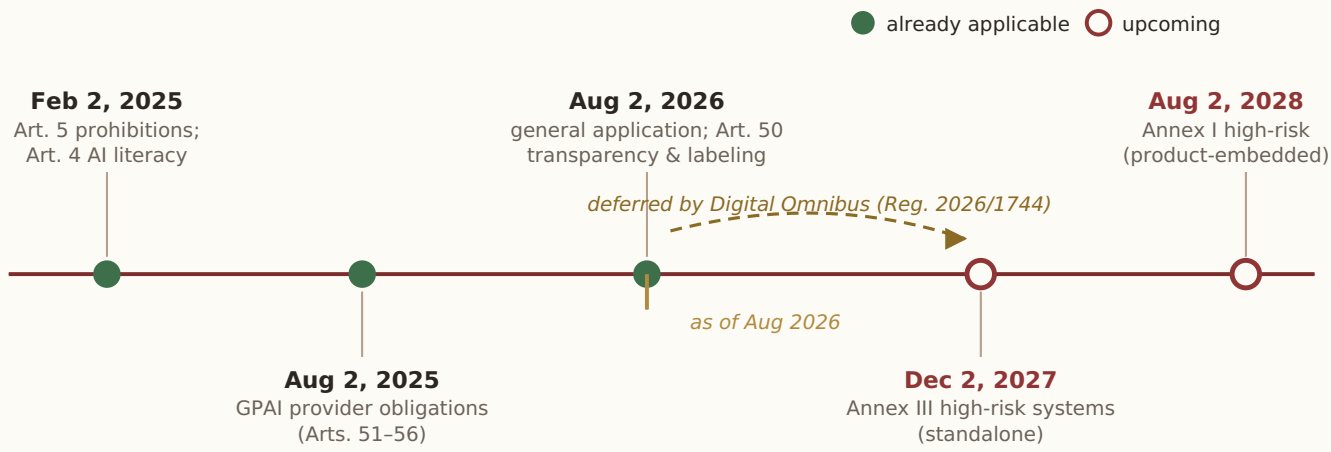


Figure 1.3. The EU AI Act compliance calendar after the July 2026 Digital Omnibus. Prohibitions, GPAI duties, and Article 50 transparency remain on their original dates; the high-risk regime moves to late 2027 and 2028.

In the United States, no federal AI act exists, and none is imminent. What exists instead is enforcement by interpretation — the FTC, CFPB, EEOC, SEC, and state attorneys general applying their existing statutes to AI conduct — plus an accelerating layer of state legislation, from Colorado's first-in-the-nation comprehensive AI act to New York City's bias-audit mandate for automated hiring tools. Chapters 6 and 7 map that terrain. The governance implication is the same on both continents: an organization cannot wait for regulatory certainty, because the operative rules already apply, and the new ones arrive on dates that are known.

Korea completed the trio in January 2026. The **AI Basic Act (Act No. 20676)** and its Enforcement Decree took effect on **January 22, 2026**, making Korea the second jurisdiction after the EU with a comprehensive horizontal AI statute — one that applies extraterritorially to foreign operators whose AI products or services affect the Korean market. The Act imposes advance-notice and labeling duties on generative AI, lifecycle safety and reliability obligations on **"high-impact" AI** in domains such as employment, healthcare, finance, and public services, and additional safety duties on **"high-performance" AI** above a compute threshold of 10^{26} FLOPs. Administrative fines are modest — capped at **30 million won** — and the Ministry of Science and ICT is operating a grace period of at least one year, deferring fines except in cases of serious social harm. But the structural signal outweighs the penalty arithmetic: for any company serving Korean users, AI governance is now a market-entry condition, larger foreign operators must designate a domestic representative, and Korea's privacy regulator has already shown that its remedies can reach the model itself. Chapter 8 treats the regime in full.

KEY TAKEAWAY

The question "is AI regulated yet?" is malformed. Existing law has always applied to AI and is being actively enforced; the new AI-specific regimes add obligations on published timetables. Governance must satisfy both layers simultaneously.

1.3 The cost asymmetry

Boards allocate against expected cost, so the economics deserve to be stated plainly. On the cost-of-failure side, the figures in Section 1.1 are floors, not ceilings: they are what enforcement has already collected, before the EU AI Act's penalty regime becomes fully operative and before US state statutes mature into enforcement. To the direct penalties must be

added litigation and settlement costs, remediation under regulatory supervision, the operational cost of systems withdrawn from production, and the commercial cost of lost enterprise customers — because AI governance questionnaires are now a standard component of B2B procurement, and a deal lost to a failed diligence review never appears in any enforcement statistic.

Named research adds a quantified dimension on the security-adjacent portion of the risk. **IBM's Cost of a Data Breach Report 2025** found that breaches involving ungoverned, unsanctioned "shadow AI" carried materially higher costs than the global average, and that a substantial share of organizations suffering AI-related security incidents lacked basic AI access controls and governance policies — a direct, measured link between the absence of governance and the size of the loss. **Stanford University's AI Index** has documented a sustained year-over-year rise in publicly reported AI incidents alongside a sharp acceleration in legislative activity, which is to say: the hazard rate and the enforcement capacity are rising together.

On the cost-of-governance side, the required investment is real but bounded and largely front-loaded: an inventory and classification exercise, a governance function with named ownership, assessment and testing processes proportionate to risk tiers, and an evidence layer. Part III of this book prices and sequences that build over twelve months. The asymmetry is structural: governance cost is planned, incremental, and capitalizable into every subsequent AI deployment, while failure cost is unplanned, concentrated, and compounding. One is a budget line; the other is a contingency you do not control.

COST OF INACTION

The documented record through 2026 includes a €1.2 billion data protection fine, an $89 million consumer finance order, multi-million-dollar biometric settlements, the first AI-discrimination settlements and vendor-liability rulings in US employment law, securities penalties for overstated AI claims, and a governmental collapse triggered by an algorithm. Every one of these was preventable at the governance layer.

1.4 The affirmative case

The defensive case would suffice, but it understates the position, because governance has become a commercial capability. Three mechanisms drive this. First, **procurement**: enterprise buyers, prompted by their own regulatory exposure, now interrogate their vendors' AI governance as a condition of contract, and a documented, audit-ready program shortens sales cycles that an undocumented one stalls. Second, **deployment velocity**: organizations with a functioning classification and gating process approve low-risk AI uses quickly and confidently, while organizations without one either freeze all adoption out of generalized fear or approve everything out of ignorance — both of which are competitive failures. Third, **capital markets and M&A**: AI governance has entered diligence checklists, and the ability to produce a system inventory, risk classifications, and assessment records on request is now a component of enterprise value, much as security certifications did a decade ago.

The chapter's conclusion is the book's premise: AI governance belongs on the board agenda not because regulation demands ritual attention, but because the organization's exposure and its opportunity now run through the same set of systems, and both are governable. The next chapter supplies the framework for governing them.

COMMON FAILURE PATTERN

Treating AI governance as an annual policy-approval exercise. The documented failures in this chapter were not caused by absent policies; they were caused by absent inventories, absent owners, absent testing, and absent evidence. A policy without those four is a press release.

SOURCES AND VERIFICATION

The following primary instruments, enforcement actions, and named research underlie this chapter's factual claims. Statutes are amended in place and guidance is superseded; verify the operative text and the most recent regulatory guidance before relying on any entry. Facts verified against primary and authoritative secondary sources as of August 2026.

- Regulation (EU) 2024/1689 (EU AI Act), including Article 5 (prohibited practices), Articles 50–56 (transparency and general-purpose AI obligations), and Article 99 (penalty tiers up to €35 million or 7 percent of global annual turnover)
- Regulation (EU) 2026/1744 (Digital Omnibus on AI), published in the Official Journal on July 24, 2026 and in force July 27, 2026: deferral of Annex III high-risk obligations to December 2, 2027 and Annex I product-embedded obligations to August 2, 2028; Article 50 transparency duties retained on the August 2, 2026 date
- Regulation (EU) 2016/679 (GDPR), Article 83 (administrative fines up to €20 million or 4 percent of global annual turnover)
- Irish Data Protection Commission decision against Meta Platforms Ireland, May 2023 (€1.2 billion fine concerning EU–US data transfers)
- Garante per la Protezione dei Dati Personali: temporary limitation on ChatGPT processing (March 2023) and fine of €15 million against OpenAI (December 2024)
- US Equal Employment Opportunity Commission, settlement with iTutorGroup, 2023 ($365,000; age-based automated rejection of applicants)
- *Mobley v. Workday, Inc.* (N.D. Cal.): rulings permitting discrimination claims against an AI screening vendor to proceed
- Consumer Financial Protection Bureau, consent orders against Apple Inc. and Goldman Sachs Bank USA, October 2024 (combined penalties and redress exceeding $89 million concerning the Apple Card program)
- New York State Department of Financial Services, Report on the Apple Card Investigation, March 2021 (no finding of unlawful discrimination under fair lending law; transparency and customer-service deficiencies identified)
- US Securities and Exchange Commission, settled charges against Delphia (USA) Inc. and Global Predictions Inc., March 2024 (combined civil penalties of $400,000 for misleading AI-capability statements)
- Clearview AI: settlement of Illinois Biometric Information Privacy Act litigation valued at approximately $50 million, and administrative fines by multiple European data protection authorities
- Parliamentary inquiry and cabinet resignation in the Netherlands, January 2021, concerning the childcare benefits scandal (algorithmic risk scoring by the Dutch tax administration)
- Documented facial recognition wrongful arrest cases: Robert Williams (Detroit, 2020) and Porcha Woodruff (Detroit, 2023)
- Personal Information Protection Commission (Korea), sanction against Scatter Lab Inc., April 2021 (103.3 million won in fines and penalty surcharges concerning the "Lee Luda" chatbot; unlawful use of messenger data for AI training; corrective orders reaching the unlawfully processed data)
- Act No. 20676 (Korea AI Basic Act) and Presidential Decree No. 36053 (Enforcement Decree), in force January 22, 2026: extraterritorial application; generative AI notice and labeling duties; high-impact AI obligations; high-performance AI compute threshold of 10^{26} FLOPs; administrative fines capped at 30 million won; MSIT grace period of at least one year for fines except in cases of serious social harm
- IBM, Cost of a Data Breach Report 2025 (elevated costs associated with shadow AI; prevalence of missing AI access controls and governance policies among affected organizations)
- Stanford University Institute for Human-Centered AI, AI Index Report (documented rise in AI incident counts and in legislative activity)



CHAPTER 2

The Governance Framework: Know, Own, Control, Prove

The decision this chapter supports. How to structure the organization's entire AI governance effort so that every current and future obligation — from any regulator, in any jurisdiction — has a predictable landing zone. This is the one chapter no reader should skip.

In this chapter. The four commitments of the framework and what each requires in practice; how the framework absorbs new regulation without reorganization; a four-level maturity scale for honest self-assessment; and the failure patterns that each commitment is designed to prevent.

2.1 Why executives need one model

The regulatory landscape described in Part II is jurisdictionally fragmented and textually vast. No executive can hold it in mind, and no executive should try. What an executive can and must hold in mind is a stable internal model of what a governed AI estate looks like, so that every new statute, guidance document, or auditor request can be routed to the part of the organization that handles it. Absent such a model, each new obligation triggers an ad hoc project; with one, it triggers a routing decision.

The model this book uses is deliberately minimal: four commitments, each a verb, each with a definable owner and a definable output. **Know** — the inventory. **Own** — the accountability map. **Control** — the proportionate safeguards. **Prove** — the evidence layer. Regulations differ enormously in their text and hardly at all in their anatomy: virtually every obligation in the EU AI Act, the GDPR, the US state statutes, and the sector rules examined later in this book is, on inspection, a demand that an organization know what it operates, assign responsibility for it, control it proportionately to its risk, or prove that it has done the first three. The framework is therefore not a summary of current law; it is the shape into which law of this kind resolves, which is what allows it to absorb regulation that has not been written yet.

2.2 KNOW: the inventory and classification

Every governance failure examined in Chapter 1 had, somewhere near its root, an organization that did not fully know what it was operating — which systems existed, what data they consumed, what decisions they influenced, and which humans, if any, stood between model output and real-world effect. The first commitment is therefore a complete, current, and owned inventory of AI systems: **built, bought, and embedded**. The third category is the one organizations most reliably miss. AI now arrives inside SaaS products, productivity suites, HR platforms, and customer-service tooling whether or not anyone procured it as AI, and an inventory process that relies on teams self-declaring their "AI projects" will systematically undercount the estate. The inventory must be built from procurement records, vendor contracts, and technical discovery, not from a survey.

Counting is not yet knowing. Each system must be classified along two axes: **legal risk tier** and **business criticality**. The legal axis borrows its structure from the EU AI Act because that structure — prohibited, high-risk, limited-risk transparency cases, minimal risk — has become the de facto international vocabulary, one that Korea's "high-impact AI" category deliberately echoes, and because classifying against the strictest applicable regime once is cheaper than classifying against every regime separately. The business axis asks what the system touches: revenue, employees, customers, regulated decisions, brand. A system's governance intensity is set by the higher of its two classifications. The output of the Know commitment is a single register, refreshed on a defined cycle and at every deployment gate, that any director can request and receive within a day.

BOARD QUESTION

How many AI systems does this organization operate today — built, bought, and embedded — and when was that number last verified against procurement records rather than self-reporting?

2.3 OWN: named accountability

The second commitment converts the inventory into an accountability map. Its rule is simple and non-negotiable: **every system and every recurring obligation has exactly one named senior owner.** Committees coordinate, advise, and escalate; they do not own, because a risk owned by a committee is owned by no one, and every regulator and plaintiff's lawyer knows it. The ownership model that works in practice has three tiers: an executive sponsor with budget authority and board access (in larger organizations, a Chief AI Officer or equivalent; in smaller ones, an existing C-level executive with the mandate added explicitly to their charter); functional owners for the recurring obligations — privacy assessments, model testing, vendor diligence, incident response — drawn from legal, privacy, engineering, security, and compliance; and a system owner of record for each entry in the inventory, accountable for that system's classification being current and its controls being operative.

Ownership must be written down, resourced, and made consequential — it appears in role charters and performance objectives, or it does not exist. Chapter 11 develops the organizational design in full, including the cross-functional AI governance committee that coordinates the owners. The committee is valuable precisely once ownership is individual: it becomes the place where owners surface conflicts and dependencies, rather than a place where accountability diffuses.

COMMON FAILURE PATTERN

Governance by standing committee without individual ownership. The symptom is a committee that meets regularly, minutes diligently, and cannot, when asked, name the single person accountable for the highest-risk system in production. Regulators encountering this structure treat it — correctly — as the absence of governance.

2.4 CONTROL: proportionate safeguards and gates

The third commitment is where governance touches the systems themselves, and its governing principle is **proportionality**. Uniform maximal control is a common and expensive mistake: it exhausts the governance budget on trivial systems, provokes organizational resistance that ultimately weakens oversight of the systems that matter, and is required by no regulator. Control intensity follows the classification from the Know commitment. Minimal-risk systems receive baseline hygiene: inventory registration, vendor terms, acceptable-use rules. Transparency-tier systems add the disclosure and labeling duties that, in the EU, apply from August 2026 under Article 50 of the AI Act, and that Korea's AI Basic Act has imposed on generative AI since January 2026. High-risk systems receive the full apparatus: documented risk assessment before deployment, bias and performance testing against defined thresholds, human oversight designed into the workflow rather than asserted in policy, production monitoring for drift and anomaly, and an incident response path with defined escalation.

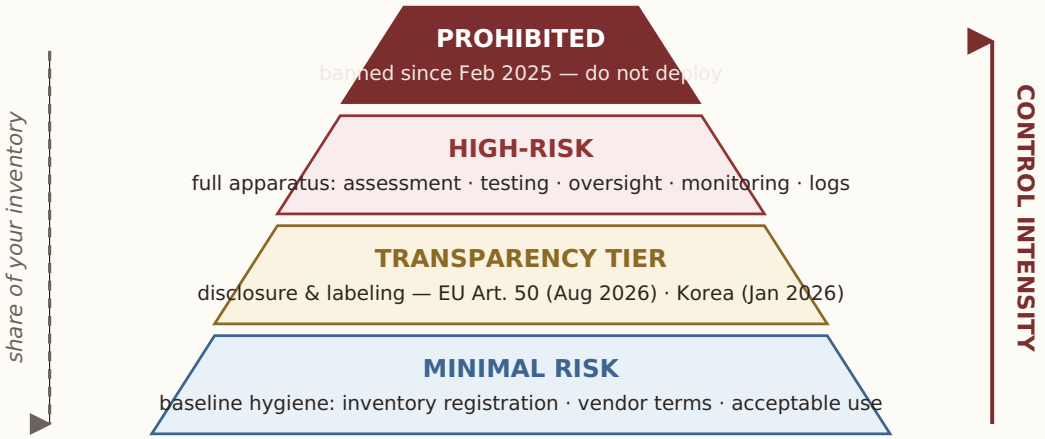


Figure 2.1. Proportionate control. The tier vocabulary follows the EU AI Act's risk architecture; most systems in a typical inventory sit in the lower tiers, and governance budget should follow the pyramid, not fight it.

The operative mechanism binding these controls together is the **deployment gate**: a defined checkpoint that no system crosses without its classification confirmed, its required assessments completed, its owner identified, and — for the higher tiers — its testing results reviewed and its human-oversight design approved. Gates convert governance from retrospective review into a precondition of launch, which is the only position from which governance can actually prevent anything. The gate criteria are set centrally by the governance function; the evidence that a system meets them is produced by the teams that build or buy it. Chapter 12 sequences the build; Chapter 14 applies the gate logic to the three decisions executives face most often.

2.5 PROVE: the evidence layer

The final commitment reflects a fact about modern regulation that executives internalize slowly: regulators do not primarily ask organizations to *be* compliant; they ask organizations to *demonstrate* compliance, and the demonstration is documentary. The GDPR names this the **accountability principle** — the controller is responsible for, and must be able to demonstrate compliance with, the regulation's principles — and the EU AI Act's high-risk regime is, in operational substance, a list of documents and records that must exist and be maintained: technical documentation, risk management records, logging, post-market monitoring. US enforcement runs on the same fuel from the opposite direction: in litigation and agency investigation, the absence of testing records, assessment documentation, and decision logs is read as the absence of care.

The executive instruction that follows is to make **evidence a build artifact rather than an archaeology project**: assessments, test results, gate decisions, and monitoring outputs are generated and filed at the moment they occur, in a defined repository, to a defined retention schedule. An organization that does this holds a standing capability that compounds — each audit, customer questionnaire, and regulatory inquiry is answered from the file. An organization that does not will meet its first serious inquiry by reconstructing the past under deadline, at legal rates, with the answer's credibility discounted by its provenance.

KEY TAKEAWAY

Know what you run; give everything an owner; control in proportion to risk; and generate the proof as you go. Every obligation in Part II of this book is one of these four demands wearing statutory language.

2.6 An honest maturity scale

Boards benefit from a shared vocabulary for where the organization actually stands. Four levels suffice.

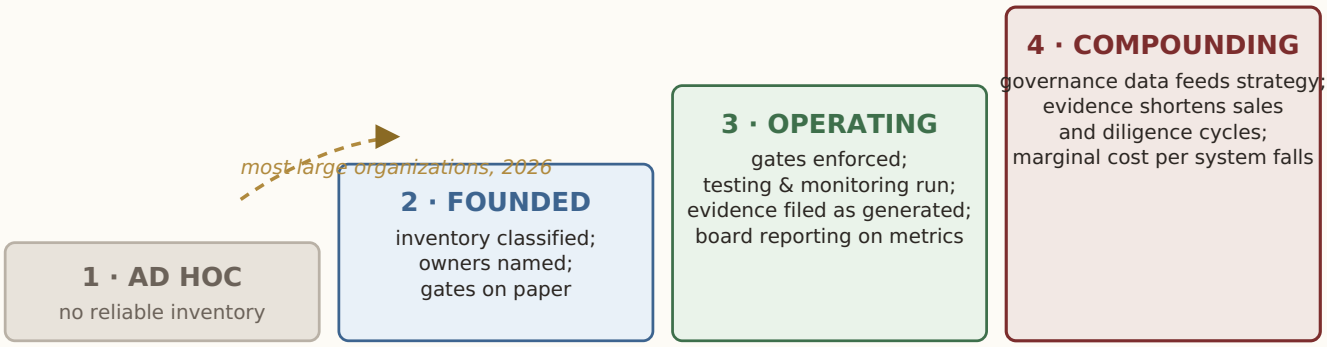


Figure 2.2. The governance maturity staircase. The twelve-month roadmap in Chapter 12 is the climb from the first two steps to Level 3; Level 4 is where governance begins returning value.

LEVEL	NAME	WHAT IT LOOKS LIKE
1	**Ad hoc**	No reliable inventory; AI adoption is happening but ungoverned; policies may exist and are not connected to systems
2	**Founded**	An inventory exists and is classified; owners are named; the highest-risk systems have assessments; gates exist on paper
3	**Operating**	Gates are enforced in practice; testing and monitoring run on schedule; evidence is filed as generated; the board receives regular reporting against defined metrics
4	**Compounding**	Governance data feeds strategy — classification informs the AI roadmap, evidence shortens sales and diligence cycles, and the marginal cost of governing each new system falls

Most large organizations in 2026, measured honestly, sit between Levels 1 and 2. The twelve-month roadmap in Chapter 12 is the path from there to Level 3. Directors should ask for the self-assessment, ask what evidence supports the claimed level, and treat an answer of Level 3 or above that arrives without documentary support as a claim of Level 1.

SOURCES AND VERIFICATION

The following primary instruments and named standards underlie this chapter's factual claims. Verify the operative text before relying on any entry. Facts verified as of August 2026.

- Regulation (EU) 2024/1689 (EU AI Act): the risk-tier architecture (Articles 5, 6 and Annex III, Article 50), and the high-risk documentation, risk management, logging, human oversight, and post-market monitoring obligations (Articles 9–17, 26, 72)
- Regulation (EU) 2026/1744 (Digital Omnibus on AI): revised application dates for the high-risk obligations; Article 50 transparency duties applicable from August 2, 2026
- Regulation (EU) 2016/679 (GDPR), Article 5(2) (accountability principle) and Article 24 (responsibility of the controller)
- Act No. 20676 (Korea AI Basic Act) and its Enforcement Decree, in force January 22, 2026 (generative AI notice and labeling duties; the "high-impact AI" risk category referenced in the classification discussion)
- NIST AI Risk Management Framework (AI RMF 1.0), whose Govern–Map–Measure–Manage functions parallel the inventory, classification, control, and monitoring commitments described in this chapter
- ISO/IEC 42001:2023 (AI management systems), the certifiable management-system standard whose documentation and continual-improvement requirements correspond to the Prove commitment
- The framework presented in this chapter (Know, Own, Control, Prove) and the four-level maturity scale are the author's synthesis, offered as planning constructs rather than as measured research findings

◆ ◆ ◆

CHAPTER 3

Where Accountability Sits

The decision this chapter supports. How the board and executive team should allocate AI oversight among themselves — what the board retains, what management owns, and what may be delegated without being abdicated.

In this chapter. The legal sources of director and officer accountability for AI: fiduciary oversight duties, the accountability structures written into the EU regimes, disclosure obligations, and the practical accountability map that follows from them. This chapter describes the legal landscape for governance planning; it is not legal advice, and the application of these doctrines to any specific organization is a matter for counsel.

3.1 The fiduciary baseline

In US corporate law, the foundational statement of the board's oversight duty remains the Delaware Court of Chancery's decision *In re Caremark International Inc. Derivative Litigation* (1996), as affirmed and sharpened by the Delaware Supreme Court in *Marchand v. Barnhill* (2019): directors must make a good-faith effort to ensure that the corporation has reasonable information and reporting systems for the risks central to its business, and must not ignore red flags those systems raise. Caremark claims are famously hard for plaintiffs to win — liability requires bad faith, not mere negligence — but *Marchand* and its successors demonstrated that boards which fail to establish any monitoring system for a mission-critical risk face real exposure. The doctrinal question a board should therefore ask is not whether AI oversight failures are likely to produce personal liability tomorrow; it is whether AI has become **mission-critical** to the enterprise — and for a growing share of companies the honest answer is yes, which places AI within the category of risks for which some board-level information and reporting system must demonstrably exist.

The practical consequence is modest and concrete: a board that receives periodic, documented reporting on the AI estate — the inventory, the classifications, the status of controls, the incidents — and that engages with red flags on the record, has substantially discharged the oversight duty as the courts have framed it. A board that cannot show any such system has left the question open. The standing board agenda in Chapter 15 is designed to close it.

3.2 Accountability written into the European and Korean regimes

The European instruments do not rely on fiduciary doctrine; they write accountability into the operative text. The GDPR's **accountability principle (Article 5(2))** makes the controller — the legal entity, acting through its management — responsible for demonstrating compliance, and its fine ceilings are calibrated to the undertaking's global turnover precisely so that responsibility cannot be quarantined in a subsidiary. The EU AI Act distributes obligations by role in the value chain — provider, deployer, importer, distributor — and its high-risk regime requires, among much else, a quality management system, human oversight arrangements, and post-market monitoring, all of which are management-system obligations that regulators will assess at the organizational level, not artifacts that can be delegated to a data science team. **Article 4** of the AI Act adds a duty, applicable since February 2025, for providers and deployers to ensure a sufficient level of **AI literacy** among the staff dealing with AI systems on their behalf — a legislative statement, rarely noticed at board level, that competence itself is now an obligation.

Two further features of the European architecture deserve board attention. First, penalty exposure under the AI Act reaches **€35 million or 7 percent of global annual turnover** for prohibited practices — above the GDPR ceiling — and the prohibitions have applied since February 2025 regardless of the Omnibus deferrals. Second, the regimes are **cumulative**: a

single AI system processing personal data in Europe can simultaneously engage the AI Act, the GDPR, and sectoral law, and enforcement under one does not preclude enforcement under another. Chapter 9 treats the program-level consequence: one system of governance must satisfy multiple regimes at once.

Korea writes accountability in similar ink. The AI Basic Act applies extraterritorially to foreign operators whose AI products or services affect the Korean market, and its Enforcement Decree requires larger foreign operators — those meeting thresholds such as one trillion won in total prior-year revenue, ten billion won in AI-service revenue, or an average of one million daily Korean users over the preceding three months — to designate a **domestic representative** who supports the operator's safety-measure reporting, high-impact AI identification, and safety and reliability obligations: a named, in-country point of accountability created by statute. Korean privacy law runs in parallel — the Personal Information Protection Act requires organizations to designate a privacy officer responsible for data protection — and the PIPC demonstrated as early as the Scatter Lab case that its corrective powers can reach the data and systems themselves. The pattern across all three jurisdictions is the same: the law increasingly names the seat where accountability must sit, and expects to find a person in it.

BOARD QUESTION

If a European or Korean regulator asked tomorrow who in this organization is accountable for our highest-risk AI system's compliance — by name, with documented authority — what answer would we give, and is it written down anywhere the regulator would find persuasive?

3.3 Disclosure and the securities dimension

For public companies, AI accountability has a disclosure dimension that boards already know how to reason about, because it is the cybersecurity story repeating. Statements to investors about AI capabilities, revenues, and risks are securities statements: the SEC's 2024 actions against Delphia and Global Predictions established that overstating AI use is chargeable as fraud under the Advisers Act, and the agency's leadership has repeatedly warned public companies against **"AI washing"** in filings and investor communications. The same logic runs in reverse: as AI systems become material to operations, their failures become material events, and the adequacy of risk-factor disclosure about AI — like the adequacy of cyber disclosure before it — will be judged after the incident, with hindsight. The board's disclosure committee machinery, already tuned by the cyber experience, should explicitly include AI: **what we say about our AI must match what the inventory and evidence layer show we actually do**, which is one more reason the Prove commitment of Chapter 2 is a board concern and not a records-management detail.

3.4 The accountability map

The doctrines above resolve into a practical allocation, which this book recommends as a starting position and Part III develops in structural detail.

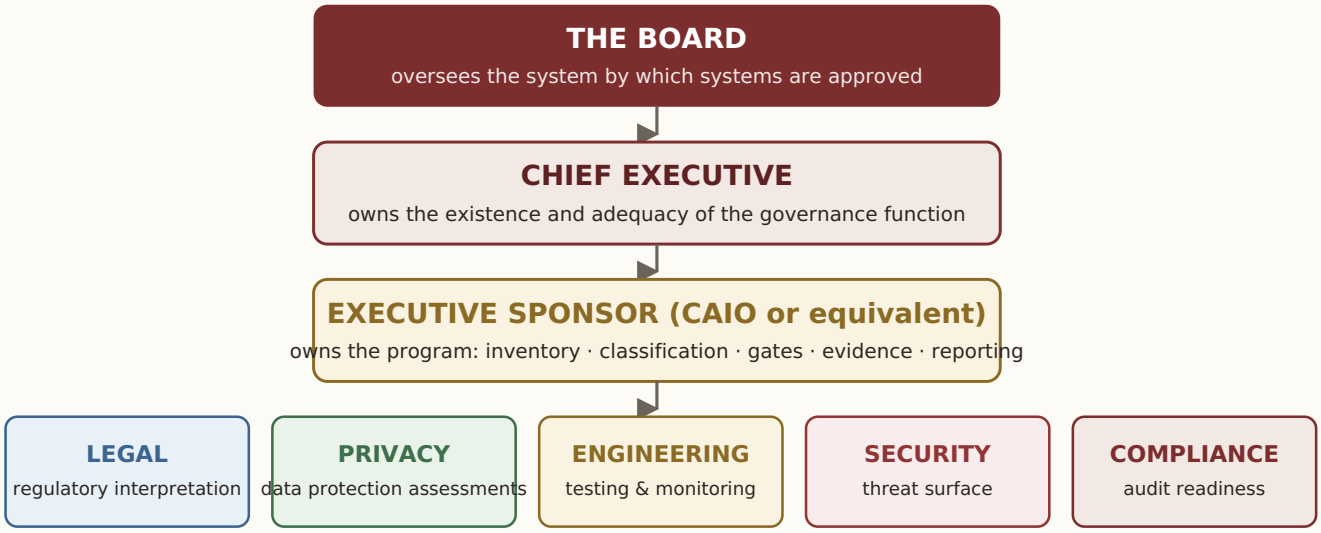


Figure 3.1. The accountability map. Each layer owns something distinct; delegation flows downward with a documented record, and reporting flows back up. A risk owned by a committee is owned by no one.

ROLE	WHAT THEY OWN
The board	Oversight of AI as a category of enterprise risk: approves the governance framework and risk appetite, receives reporting on the inventory and control status at a defined cadence, engages with incidents and red flags on the record, and satisfies itself annually that the program is resourced. The board does not approve individual systems; it approves *the system by which systems are approved*.
The chief executive	The existence and adequacy of the governance function: appoints the executive sponsor, allocates the budget, resolves conflicts between governance and business units, and is accountable to the board for the maturity level honestly assessed.
The executive sponsor (Chief AI Officer or equivalent)	The program: the inventory, the classification methodology, the gate criteria, the evidence layer, and the reporting to CEO and board. Whether this is a dedicated Chief AI Officer or a mandate added to an existing executive is a sizing question treated in Chapter 11; that it is *one named person* is not.
Functional leaders	Their obligations within the program — legal owns regulatory interpretation, privacy owns data protection assessments, engineering owns testing and monitoring, security owns the threat surface, compliance owns audit readiness — each as defined duties in the accountability map, not as volunteered goodwill.

Delegation along this map is legitimate and necessary; abdication is neither. The distinction is evidentiary: delegation leaves a record — charters, reporting, minuted engagement — while abdication leaves silence. Every doctrine surveyed in this chapter, from *Caremark* to the accountability principle, ultimately tests for the same thing: **when the failure occurred, was anyone demonstrably watching?** The remainder of this book is a manual for being able to answer yes.

KEY TAKEAWAY

Accountability for AI cannot be transferred to a vendor, a committee, or a policy document. The board oversees the system of governance; the CEO owns its existence; one named executive owns the program; functional leaders own their obligations. Everything else in this book assumes that map.

SOURCES AND VERIFICATION

The following primary instruments and enforcement actions underlie this chapter's factual claims. Verify the operative text before relying on any entry. Facts verified as of August 2026.

- *In re Caremark International Inc. Derivative Litigation*, 698 A.2d 959 (Del. Ch. 1996), and *Marchand v. Barnhill*, 212 A.3d 805 (Del. 2019) (board oversight duties for mission-critical risk)
- Regulation (EU) 2016/679 (GDPR), Articles 5(2), 24, and 83 (accountability principle, controller responsibility, and turnover-based fines)
- Regulation (EU) 2024/1689 (EU AI Act), Articles 4 (AI literacy, applicable from February 2, 2025), 9–17 and 26 (high-risk provider and deployer obligations, including quality management and human oversight), and 99 (penalties)
- Regulation (EU) 2026/1744 (Digital Omnibus on AI) (deferral of high-risk application dates; prohibitions and transparency duties unaffected in the respects described)
- Act No. 20676 (Korea AI Basic Act) and Presidential Decree No. 36053 (Enforcement Decree), in force January 22, 2026 (extraterritorial application; domestic representative requirement and its thresholds, including one trillion won total revenue, ten billion won AI-service revenue, or one million average daily Korean users)
- Personal Information Protection Act (Korea) (designation of a privacy officer responsible for data protection), and Personal Information Protection Commission enforcement practice including the Scatter Lab corrective orders (April 2021)
- US Securities and Exchange Commission, settled charges against Delphia (USA) Inc. and Global Predictions Inc., March 2024, and public agency statements warning against "AI washing" in investor communications
- The accountability map in Section 3.4 is the author's recommended allocation, offered as a planning construct; its legal sufficiency for any particular organization is a matter for qualified counsel

End of Part I · Part II — The Three Regimes — begins with Chapter 4: The EU AI Act After the Omnibus.

PART II

THE THREE REGIMES

The EU AI Act after the Omnibus, the GDPR applied to AI, US federal enforcement, US state law, Korea's AI Basic Act — and how one program satisfies all of them.

CHAPTER 4

The EU AI Act After the Omnibus

The decision this chapter supports. How to allocate effort against the EU AI Act's re-drawn calendar: what must be operating now, what the deferral to late 2027 buys, and what to build during the window rather than after it closes.

In this chapter. A structured entry on Regulation (EU) 2024/1689; the risk-tier architecture; what the July 2026 Digital Omnibus changed and what it deliberately left in place; the high-risk regime as a build specification; and the general-purpose AI layer that reaches model providers directly.

4.1 The regulation in one view

Instrument	Regulation (EU) 2024/1689 (EU AI Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI)
Jurisdiction & reach	European Union; extraterritorial — reaches providers placing AI systems on the EU market and providers/deployers whose system outputs are used in the EU, wherever the operator is established
In force	August 1, 2024, with staggered application (see 4.2); Omnibus amendments in force July 27, 2026
Regulators	National market surveillance authorities; the European Commission's AI Office for general-purpose AI models
Architecture	Risk-tiered: prohibited practices (Art. 5); high-risk systems (Art. 6, Annexes I and III) with provider duties (Arts. 9–17) and deployer duties (Art. 26); transparency cases (Art. 50); general-purpose AI models (Arts. 51–56); minimal risk unregulated
Penalties	Up to €35M or 7% of global annual turnover for prohibited practices; up to €15M or 3% for most other violations; up to €7.5M or 1% for supplying misleading information
Executive implication	The Act is a management-system statute: what it ultimately demands is a documented, tested, monitored governance apparatus — the Know-Own-Control-Prove build of Chapter 2, with EU-specific artifacts attached

4.2 The calendar that matters

The Act's obligations arrive in waves, and the July 2026 Digital Omnibus re-set only some of them. Three waves are already operative. Since **February 2, 2025**, the Article 5 prohibitions apply — social scoring by public authorities, exploitative manipulation of vulnerable groups, untargeted scraping of facial images to build recognition databases, emotion recognition in workplaces and schools (with narrow exceptions), and related practices — alongside the Article 4 AI-literacy duty. Since **August 2, 2025**, general-purpose AI model providers carry the obligations of Articles 51–56, supported by the Commission's GPAI Code of Practice published in July 2025. And from **August 2, 2026**, the Act applies generally, including the Article 50 transparency duties: people must be told when they interact with an AI system, and AI-generated or manipulated content — including deepfakes — must be disclosed and machine-readably marked.

What the Omnibus moved is the high-risk regime. Obligations for standalone Annex III high-risk systems — the employment, credit, education, essential-services, and similar use cases — now apply from **December 2, 2027**; obligations for AI embedded in products already regulated under EU product-safety law (Annex I) apply from **August 2, 2028**. The Omnibus also added two new prohibited categories to Article 5 — systems that generate non-consensual intimate imagery and child sexual abuse material — with a grace period for the associated technical safeguards, and for the watermarking sub-obligation for systems already on the market before August 2026, running to **December 2, 2026**.

The executive reading of this calendar is disciplined, not relaxed. The deferral was granted because the harmonized standards that give high-risk systems a presumption of conformity were not ready — the requirements themselves did not change, only the date on which they bite. An organization that treats December 2027 as a start date will attempt an eighteen-month build in six; an organization that treats it as a completion date runs the Chapter 12 roadmap once, calmly, and arrives with evidence in hand.

KEY TAKEAWAY

As of August 2026, the prohibitions, the AI-literacy duty, the GPAI obligations, and the Article 50 transparency and labeling duties are live. Only the high-risk apparatus moved — to December 2027 and August 2028 — and it moved because the standards were late, not because the requirements shrank.

4.3 The high-risk regime as a build specification

For a company with any Annex III use case — hiring and worker management, credit scoring, education and vocational access, essential public and private services, and the other enumerated domains — the high-risk chapter of the Act is best read as an engineering and management specification with legal force. Providers must operate a risk management system across the lifecycle (Art. 9), meet data and data-governance requirements for training, validation, and testing sets (Art. 10), maintain technical documentation and automatic logging (Arts. 11–12), design for transparency to deployers and for effective human oversight (Arts. 13–14), and achieve appropriate accuracy, robustness, and cybersecurity (Art. 15), all within a quality management system (Art. 17), completing conformity assessment and EU database registration before placing the system on the market. Deployers carry their own duties under Article 26 — using systems per instructions, assigning competent human oversight, monitoring operation, and retaining logs — and, for certain deployers, a fundamental-rights impact assessment under Article 27.

Mapped onto the framework of Chapter 2, nothing here is exotic: Articles 9–10 are Know and Control at the data layer; Articles 11–12 and 17 are Prove; Articles 13–14 and 26 are Own and Control at the point of use. The Act’s most common misreading at executive level is role confusion — assuming that buying rather than building exempts the organization. It does not: deployers have their own obligations, and a deployer that substantially modifies a high-risk system, or puts its name on it, can become a provider with the full provider stack. Chapter 13 returns to this in the vendor context.

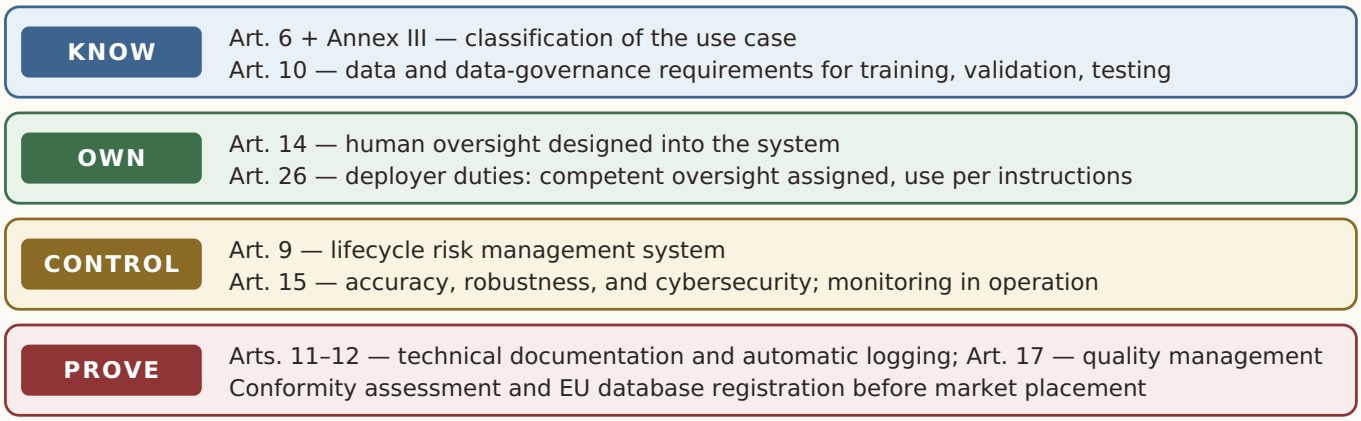


Figure 4.1. The high-risk regime is the Know-Own-Control-Prove framework in statutory form. An organization that runs the Chapter 2 build holds most of these artifacts before the December 2027 date arrives.

COMMON FAILURE PATTERN

Deferring all EU AI Act work because “high-risk doesn’t apply until 2027.” The Article 50 transparency and labeling duties apply from August 2026 to systems most enterprises already run — chatbots and generative content pipelines — and the prohibitions have applied since February 2025. The deferred deadline is the largest workstream, not the first one.

4.4 The general-purpose AI layer

The Act regulates general-purpose AI models directly — a layer that matters to executives in two directions. If the organization provides such a model, Articles 51–56 impose technical documentation, information for downstream providers, a copyright policy, and a training-content summary, with additional systemic-risk obligations above the compute threshold the Act sets for models with systemic risk. If — far more commonly — the organization builds on someone else’s model, the same provisions define what documentation the organization is entitled to demand from its model vendor, which converts a statutory obligation into a procurement checklist. The GPAI Code of Practice gives providers a compliance vehicle; a buyer’s diligence question is simply whether its vendor has adhered to it, and what evidence accompanies the claim.

BOARD QUESTION

Which of our products will trigger Article 50’s disclosure and labeling duties as of August 2026, and has anyone tested that the marking actually ships in production — not merely that a policy says it should?

SOURCES AND VERIFICATION

Verify the operative text and the most recent guidance before relying on any entry. Facts verified as of August 2026.

- Regulation (EU) 2024/1689 (EU AI Act): Articles 4, 5, 6, 9–17, 26, 27, 50, 51–56, 99; Annexes I and III
- Regulation (EU) 2026/1744 (Digital Omnibus on AI), published in the Official Journal July 24, 2026, in force July 27, 2026: deferral of Annex III obligations to December 2, 2027 and Annex I obligations to August 2, 2028; new Article 5 prohibitions on non-consensual intimate imagery and child sexual abuse material generation, with associated technical-safeguard and watermarking grace periods to December 2, 2026
- European Commission, General-Purpose AI Code of Practice (July 2025), and the Article 51 framework for general-purpose AI models with systemic risk
- Penalty tiers per Article 99 (up to €35M/7%, €15M/3%, and €7.5M/1% of global annual turnover, respectively)

CHAPTER 5

The GDPR Applied to AI

The decision this chapter supports. Where to position the privacy function inside the AI program — not as a parallel bureaucracy but as the owner of the obligations that are already enforceable today.

In this chapter. Why the GDPR, not the AI Act, is the operative AI law of the present; the four pressure points where AI systems meet it — lawful basis for training data, automated decision-making under Article 22, impact assessments, and data subject rights; and the enforcement record that defines regulator expectations.

5.1 The regulation in one view

Instrument	Regulation (EU) 2016/679 (General Data Protection Regulation)
Jurisdiction & reach	EU/EEA; extraterritorial under Article 3 — reaches non-EU organizations offering goods or services to, or monitoring, people in the EU
Applicable since	May 25, 2018
Regulators	National data protection authorities, coordinated by the European Data Protection Board (EDPB)
Core relevance to AI	Any AI system trained on, or processing, personal data of people in the EU sits inside the GDPR today — principles (Art. 5), lawful basis (Art. 6), automated decision-making (Art. 22), impact assessments (Art. 35), and the accountability principle (Art. 5(2))
Penalties	Two tiers: up to €10M or 2%, and up to €20M or 4% of global annual turnover
Executive implication	The GDPR is the enforcement machinery your AI program answers to now; AI Act readiness is largely built on top of GDPR artifacts you should already possess

5.2 Training data and lawful basis

The question that decides most AI-privacy disputes is asked at the beginning of the pipeline: on what legal basis was the training data processed? The Italian Garante's actions against OpenAI — the temporary 2023 limitation and the €15 million fine of December 2024 — turned on exactly this, together with transparency toward the people whose data was used. The EDPB's Opinion 28/2024, issued in December 2024, addressed the question at framework level: when an AI model can be considered anonymous, how legitimate interest can be assessed as a basis for training, and what follows for a model developed on unlawfully processed data. The practitioner headline for executives is that "the data was publicly available" is not a legal basis, and that the consequences of getting this wrong can attach to the model, not merely to the dataset — the remedy Korea's PIPC pioneered in the Scatter Lab case (Chapter 1) has a European analogue in this analysis.

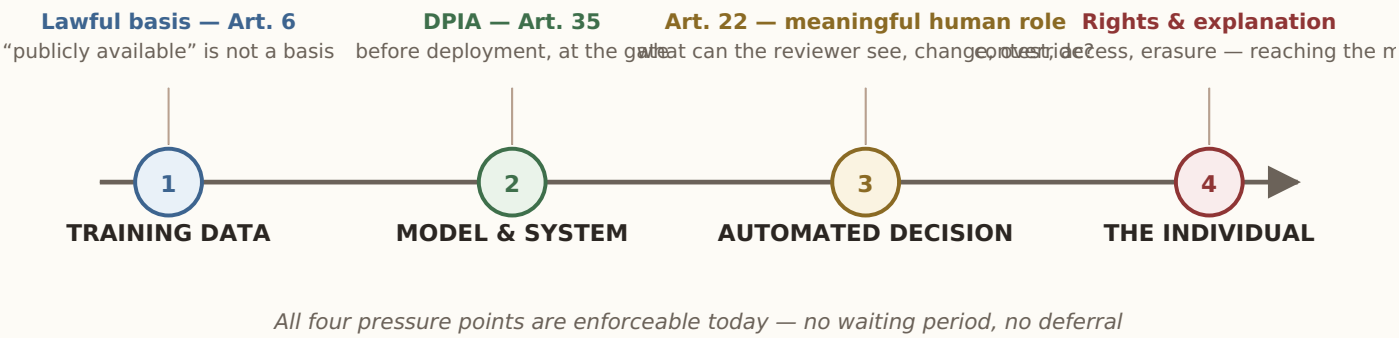


Figure 5.1. The four GDPR pressure points along the AI pipeline. Each is where an enforcement action has already landed — from the Garante’s training-data cases at checkpoint 1 to erasure remedies that reach the model at checkpoint 4.

5.3 Article 22 and the automated decision

Article 22 gives individuals the right not to be subject to decisions based solely on automated processing that produce legal or similarly significant effects — credit refusals, hiring rejections, benefit denials — unless an exception applies, and even then with safeguards: meaningful human involvement, the right to contest, and an explanation of the logic involved. Two operational truths follow. First, “human in the loop” is a design requirement, not a label: a reviewer who rubber-stamps model output at volume is not meaningful involvement, and regulators and courts examine what the human can actually see, change, and override. Second, Article 22 is the bridge between the GDPR and the AI Act’s high-risk regime — the same systems trigger both, which is why Chapter 9 insists on assessing them once, together, rather than twice in sequence.

5.4 Impact assessments and the evidence layer

Article 35 requires a data protection impact assessment where processing is likely to result in high risk to individuals — a description that captures most consequential AI deployments, and one that supervisory authorities’ DPIA lists make concrete. The DPIA is also the single most reusable artifact in the entire compliance stack: extended with the AI Act’s risk-management and fundamental-rights dimensions, it becomes the integrated assessment of Chapter 9; filed with its decisions and mitigations, it becomes Prove-layer evidence; refreshed at the deployment gate, it becomes a control. Executives should resist letting the DPIA live as a privacy-team formality: it is the document a European regulator asks for first, and the document whose absence is hardest to explain afterward.

COST OF INACTION

The GDPR’s AI enforcement record is already concrete: a €15 million fine against OpenAI over training-data legality and transparency, a temporary national ban on a flagship AI service, and the largest fine in data protection history — €1.2 billion against Meta — demonstrating the ceiling of the machinery that AI systems processing EU personal data answer to today.

BOARD QUESTION

For our highest-stakes automated decision affecting EU individuals, can management show the Article 22 analysis, the DPIA, and the design of the human review step — and when were they last updated against the system actually in production?

SOURCES AND VERIFICATION

Verify the operative text and the most recent guidance before relying on any entry. Facts verified as of August 2026.

- Regulation (EU) 2016/679 (GDPR): Articles 3, 5, 6, 22, 35, and 83
- EDPB Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (December 2024)
- Garante per la Protezione dei Dati Personali: temporary limitation concerning ChatGPT (March 2023) and €15 million fine against OpenAI (December 2024)
- Irish Data Protection Commission decision against Meta Platforms Ireland, May 2023 (€1.2 billion)
- Article 29 Working Party / EDPB guidance on automated individual decision-making and profiling, and on data protection impact assessments

CHAPTER 6

The United States I: Enforcement Without a Federal AI Act

The decision this chapter supports. How to model US federal AI risk when there is no AI statute to comply with — by tracking the agencies and the legal theories they have already used, and the new federal posture toward state law.

In this chapter. Enforcement by interpretation across the FTC, CFPB, EEOC, and SEC; the theories that recur; and the December 2025 executive order that turned the federal government from bystander into active challenger of state AI regulation.

6.1 Enforcement by interpretation

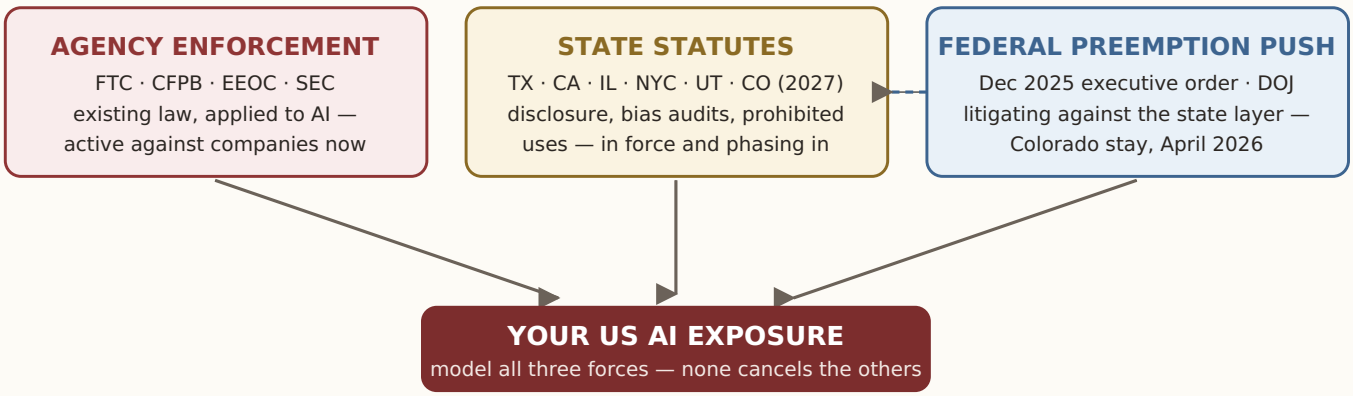
The United States regulates AI the way it has long regulated new technology: by applying old statutes through agencies with broad mandates. The pattern is consistent enough to model. The **Federal Trade Commission** polices AI under its unfairness and deception authority: its December 2023 order against **Rite Aid** banned the retailer from using facial recognition surveillance for five years after finding the technology had been deployed without reasonable safeguards, falsely flagging consumers — disproportionately in certain communities — as shoplifters; and its September 2024 **"Operation AI Comply"** sweep brought a set of actions against companies whose AI claims or AI-powered offerings misled consumers, including a settlement with **DoNotPay**, whose "robot lawyer" marketing outran the product. The FTC's message generalizes: an AI claim is an advertising claim, and an AI harm is a consumer-protection harm, no new statute required.

The **CFPB**'s Apple/Goldman order and the **EEOC**'s iTutorGroup settlement (Chapter 1) exemplify the same method in consumer finance and employment; the **SEC**'s AI-washing actions extend it to investor protection. Around these sit the standing statutes that AI does not suspend: the Equal Credit Opportunity Act and Fair Credit Reporting Act, whose adverse-action notice requirements apply with full force to algorithmic credit decisions — a lender must be able to state the specific reasons for a denial, which is an explainability requirement wearing 1970s language — and Title VII and the ADEA, under which *Mobley v. Workday* is testing how far liability reaches into the AI vendor chain.

AGENCY	LEGAL THEORY APPLIED TO AI	ILLUSTRATIVE ACTION
FTC	Unfair or deceptive acts and practices (FTC Act §5)	Rite Aid facial-recognition order (2023); Operation AI Comply sweep incl. DoNotPay (2024)
CFPB	Consumer financial protection; UDAAP; adverse-action duties	Apple / Goldman Sachs consent orders, $89M+ (2024)
EEOC	Title VII, ADEA, ADA applied to algorithmic screening	iTutorGroup settlement, $365K (2023)
SEC	Securities fraud; misleading AI-capability statements	Delphia and Global Predictions, $400K combined (2024)
Courts	Vendor liability in the employment chain	*Mobley v. Workday* permitted to proceed (N.D. Cal.)

6.2 The December 2025 executive order and the preemption push

The federal posture changed character at the end of 2025. On **December 11, 2025**, the White House issued an executive order — *Ensuring a National Policy Framework for Artificial Intelligence* — directing federal agencies to challenge state AI laws viewed as conflicting with national policy, through litigation and coordinated federal action, and urging development of a preemptive national framework. The order moved quickly from paper to courtroom: when **xAI** sued to enjoin Colorado's AI Act in April 2026, the **Department of Justice intervened** on the challenger's side, and a federal magistrate judge stayed enforcement of the Colorado law on April 27, 2026. Chapter 7 tells the Colorado story in full; the federal lesson stands on its own. For the first time, an executive planning against US AI regulation must model not two forces — agency enforcement and state legislation — but three, with the federal government actively litigating against the state layer while its own agencies continue enforcing existing law against companies.



The preemption fight targets the state layer, not the companies: agency enforcement continues regardless of how it resolves.

Figure 6.1. Since December 2025, US AI planning must model three forces, not two. The blue force litigates against the amber one — while the red one keeps enforcing against companies.

KEY TAKEAWAY

US federal AI risk is not statutory; it is enforcement risk under existing law — deception, discrimination, unfair practices, securities fraud — plus, since December 2025, a federal campaign against the state statutes. Neither force reduces the other: agency enforcement against companies continues regardless of how the preemption fight resolves.

BOARD QUESTION

If the FTC read our public statements about AI — marketing, filings, product pages — against what our systems actually do, where is the widest gap, and who owns closing it?

SOURCES AND VERIFICATION

Verify current agency guidance and litigation status before relying on any entry. Facts verified as of August 2026.

- Federal Trade Commission: order against Rite Aid Corporation (December 2023; five-year prohibition on facial recognition surveillance use); “Operation AI Comply” enforcement sweep (announced September 2024), including the settlement with DoNotPay concerning “robot lawyer” claims
- Consumer Financial Protection Bureau, consent orders against Apple Inc. and Goldman Sachs Bank USA (October 2024)
- US Equal Employment Opportunity Commission, iTutorGroup settlement (2023); *Mobley v. Workday, Inc.* (N.D. Cal.)
- US Securities and Exchange Commission, settled charges against Delphia (USA) Inc. and Global Predictions Inc. (March 2024)
- Equal Credit Opportunity Act and Fair Credit Reporting Act (adverse-action requirements applicable to algorithmic credit decisions)
- Executive Order, “Ensuring a National Policy Framework for Artificial Intelligence” (December 11, 2025); Department of Justice intervention in the xAI challenge to Colorado’s AI Act (April 2026); federal stay of enforcement (April 27, 2026)

CHAPTER 7

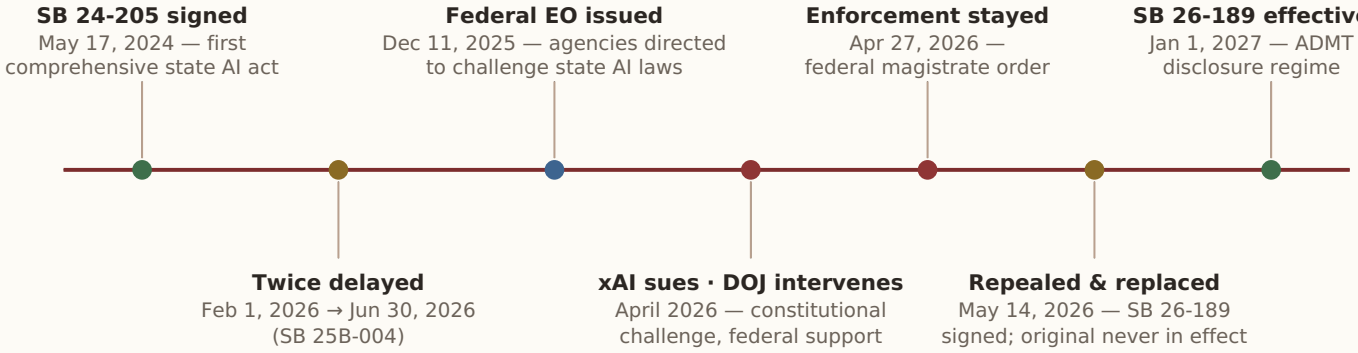
The United States II: The State Layer in Motion

The decision this chapter supports. What to actually build against a state landscape that changed shape in a single spring — and how to plan when the most ambitious statute in the country was repealed seven weeks before taking effect.

In this chapter. The Colorado story as the defining case study of 2026; the statutes in force and scheduled as of August 2026; and the planning rules that survive the volatility.

7.1 Colorado: the case study of 2026

Colorado's SB 24-205, signed May 17, 2024, was the first comprehensive state AI act and the closest American cousin of the EU model: a duty of reasonable care against algorithmic discrimination, risk management programs, impact assessments, and attorney-general reporting for high-risk systems in consequential decisions. It never took effect. Its start date was pushed from February 1, 2026 to June 30, 2026; in April 2026 xAI sued on constitutional grounds and the Department of Justice intervened in support; on April 27, 2026 a federal magistrate judge stayed enforcement; and on **May 14, 2026**, Governor Polis signed **SB 26-189**, repealing and replacing the original act with a substantially narrower framework — advance notice, post-decision disclosures, and consumer rights around **automated decision-making technology (ADMT)** used in consequential decisions, enforced by the attorney general — effective **January 1, 2027**, with the original act's duty of care, risk-management mandates, and impact-assessment obligations eliminated.



The most ambitious AI statute in the United States was repealed seven weeks before its effective date.

Figure 7.1. The Colorado arc, 2024–2027. The capabilities the original act demanded — inventory, disclosure, bias testing — survived into its replacement and into every other regime; only the statutory superstructure changed.

Three lessons transfer beyond Colorado. First, the EU-style comprehensive model is, for now, in retreat at the US state level — the surviving statutes cluster around transparency, disclosure, and specific prohibited uses rather than full management-system mandates. Second, federal pressure is a real variable: the December 2025 executive order and DOJ's intervention shaped the outcome. Third — and most important for planning — the organizations that had built inventories, classifications,

and disclosure capability lost nothing when the statute changed, because those capabilities are what the replacement law requires and what every other regime requires too. The companies that lost effort were those that had built to one statute's paperwork instead of to the underlying capability.

7.2 The map as of August 2026

INSTRUMENT	STATUS	WHAT IT DOES
Texas TRAIGA (HB 149)	In force Jan 1, 2026	Intent-based prohibitions — AI developed or deployed to manipulate behavior, unlawfully discriminate, incite harm, or produce CSAM deepfakes — with obligations concentrated on government use after legislative narrowing; adherence to the NIST AI RMF operates as a safe harbor
California AB 2013	In force Jan 1, 2026	Generative AI training-data transparency: public documentation of the datasets used to train generative systems made available to Californians
California SB 53	In force Jan 1, 2026	Frontier-model transparency and safety framework for large developers
California SB 942	Operative Aug 2, 2026	AI Transparency Act: covered generative AI providers (over one million monthly users) must offer a free AI-content detection tool and embed manifest and latent provenance disclosures; date moved from January 2026 by AB 853, with hosting-platform duties following January 1, 2027
California CPPA ADMT rules	Phased 2026–2027	Risk-assessment requirements from January 1, 2026 under the CCPA framework, with pre-use notices and consumer opt-out rights for automated decision-making taking effect January 1, 2027
Colorado SB 26-189	Effective Jan 1, 2027	ADMT disclosure regime replacing SB 24-205: advance notice, post-decision disclosure, and consumer rights in consequential decisions; attorney-general enforcement; implementation details left to rulemaking, with related enforcement questions still in federal litigation
Illinois HB 3773	In force Jan 1, 2026	Amends the Illinois Human Rights Act to make discriminatory use of AI in employment decisions a civil rights violation, with notice requirements
NYC Local Law 144	In force since 2023	Independent bias audits, publication of results, and candidate notice for automated employment decision tools used on NYC candidates and employees
Utah AI Policy Act (SB 149, as amended)	In force (2024, amended 2025)	Generative-AI disclosure duties, with heightened rules for regulated occupations and mental-health chatbots

7.3 Planning against volatility

The temptation this landscape invites is paralysis — why build against statutes that may be repealed, stayed, or preempted? The answer is that the volatility is concentrated in the statutory superstructure, not in the underlying demands. Across every version of every state law in the table, the same four capabilities recur: knowing which systems make or shape consequential decisions; telling affected people that automation is involved; being able to explain and review an adverse outcome; and testing for discriminatory effect. Those are, respectively, Know, Prove, Control, and Control again — and they are simultaneously what the EU requires, what Korea requires, and what federal agencies already enforce under old law. Build the capability, and statutory churn becomes a mapping exercise; build to a single statute's forms, and every amendment is a fire drill.

COMMON FAILURE PATTERN

Fifty-state whack-a-mole: assigning counsel to track every bill and treating each new law as a separate project. The durable posture is one national baseline — disclosure of automated decisions, bias testing, adverse-action explainability — set at the strictest applicable requirement, with a short jurisdiction-specific delta list on top.

SOURCES AND VERIFICATION

State AI law changed materially during 2026; verify current status, including litigation, before relying on any entry. Facts verified as of August 2026.

- Colorado SB 24-205 (2024) and its postponements (to February 1, 2026, then June 30, 2026 via SB 25B-004); federal stay of enforcement, April 27, 2026, in the xAI litigation with DOJ intervention; Colorado SB 26-189, signed May 14, 2026, effective January 1, 2027 (ADMT disclosure framework replacing the original act)
- Texas HB 149 (Responsible Artificial Intelligence Governance Act), effective January 1, 2026, including its prohibited-use categories and NIST AI RMF safe harbor
- California AB 2013 (generative AI training-data transparency) and SB 53 (frontier-model transparency and safety), effective January 1, 2026; SB 942 (California AI Transparency Act), operative August 2, 2026 as amended by AB 853 (2025), with hosting-platform obligations from January 1, 2027; California Privacy Protection Agency ADMT regulations (risk assessments from January 1, 2026; ADMT notice and opt-out provisions from January 1, 2027)
- Illinois HB 3773 (amendments to the Illinois Human Rights Act), effective January 1, 2026
- New York City Local Law 144 of 2021 (automated employment decision tools), enforced since July 2023
- Utah SB 149 (AI Policy Act, 2024), as amended in 2025
- Executive Order, "Ensuring a National Policy Framework for Artificial Intelligence" (December 11, 2025)

◆ ◆ ◆

CHAPTER 8

Korea: The AI Basic Act and PIPA

The decision this chapter supports. Whether and how to treat Korea as a first-order governance jurisdiction — which, for any organization with Korean users, revenue, or operations, it now is: the world's second comprehensive horizontal AI regime is in force there today.

In this chapter. A structured entry on the AI Basic Act; the three regulated categories — generative, high-impact, and high-performance AI; the grace period and what it does not suspend; the domestic-representative mechanism; and the privacy layer under PIPA and the PIPC.

8.1 The regime in one view

Instrument	Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (AI Basic Act), Act No. 20676, with its Enforcement Decree (Presidential Decree No. 36053)
Jurisdiction & reach	Republic of Korea; extraterritorial — applies to foreign businesses whose AI activities affect the Korean market and its users
In force	January 22, 2026 (Act and Enforcement Decree)
Regulator	Ministry of Science and ICT (MSIT), with subordinate notifications and guidelines; the Personal Information Protection Commission (PIPC) governs the parallel privacy layer
Architecture	Dual-purpose statute: industrial promotion (funding, talent, clusters) combined with trust obligations on three categories — generative AI (advance notice and labeling), high-impact AI (lifecycle safety, reliability, and assessment duties in domains including employment, healthcare, financial services, public safety, and education), and high-performance AI (additional safety duties above 10^{26} FLOPs of cumulative training compute)
Penalties & posture	Administrative fines capped at 30 million won; MSIT is operating a grace period of at least one year from entry into force, deferring fact-finding investigations and fines except in exceptional cases involving serious social harm
Executive implication	Compliance is a market-entry condition, not a penalty calculation: the duties apply now, the grace period is prosecutorial forbearance rather than suspension, and the reputational lever — in a market whose regulator has ordered remedies reaching models and data — exceeds the fine schedule

8.2 Three categories, three duty sets

The Act's operative logic is categorical, and an executive needs only the three categories. **Generative AI** carries transparency duties: users must be notified in advance that they are dealing with generative AI, and AI-generated content must be labeled, with the Enforcement Decree specifying the form and content of the disclosures. **High-impact AI** — systems that materially affect life, safety, or fundamental rights in enumerated domains such as employment, healthcare,

financial services, public safety, and education — carries the heaviest duties: lifecycle risk management, impact assessment, safety and reliability measures, and the ability to request MSIT confirmation of whether a given system qualifies. **High-performance AI**, defined by the Decree's compute threshold of 10^{26} cumulative FLOPs — set roughly an order of magnitude above the EU's general-purpose systemic-risk threshold — carries additional safety obligations aimed at frontier-scale developers, with safety-measure results submitted to the authorities.

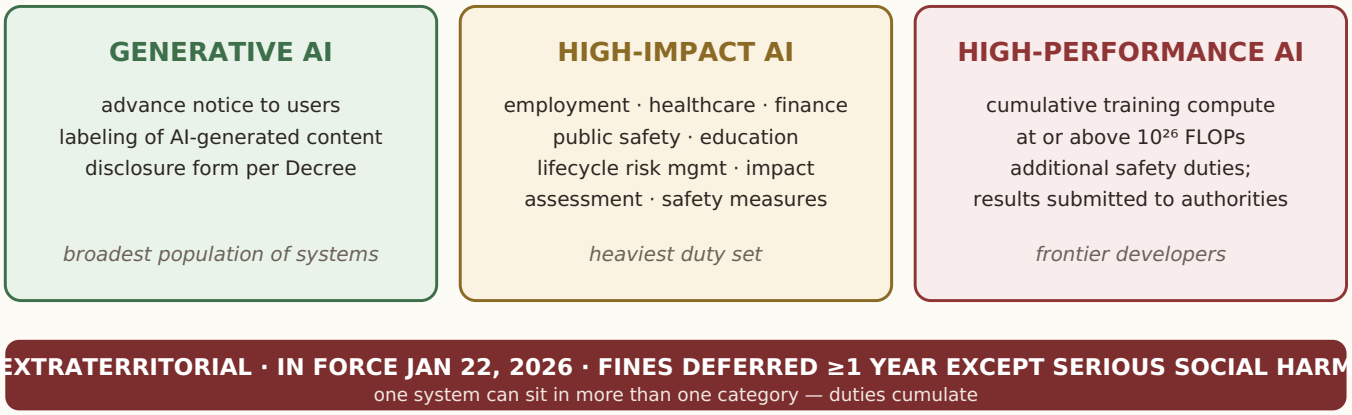


Figure 8.1. Korea's AI Basic Act regulates by category. A generative system used for hiring is both generative AI and high-impact AI, and carries both duty sets.

8.3 The domestic representative and the foreign operator

The Enforcement Decree gives the Act an in-country enforcement anchor. Foreign operators meeting specified thresholds — including one trillion won in total prior-year revenue, ten billion won in AI-service revenue, or an average of one million daily Korean users over the preceding three months — must designate a **domestic representative** with a Korean address or place of business, who represents and supports the operator in submitting large-scale AI safety-measure results, requesting high-impact AI identification, and implementing high-impact safety and reliability measures. For a global enterprise, this is Chapter 3's accountability doctrine written into foreign statute: Korea has created a named seat of accountability inside its borders and expects a person in it. Smaller operators below the thresholds are outside the representative requirement but not outside the Act, whose substantive duties apply from the January 2026 date regardless.

8.4 The privacy layer: PIPA and the PIPC

Running in parallel with the AI Basic Act is Korea's Personal Information Protection Act, substantially strengthened in recent years, and its regulator, the PIPC — the authority that produced the Scatter Lab precedent of Chapter 1 and that has since issued guidelines addressed specifically to generative AI development and deployment, functioning as a lifecycle rulebook: legal-basis documentation for training data, pseudonymization expectations, input and output filtering controls, and privacy-officer-led governance over generative AI systems. PIPA requires organizations to designate a privacy officer responsible for data protection, giving the privacy layer its own named seat of accountability alongside the AI Basic Act's domestic representative. The practical consequence for program design is the same one Chapter 5 drew for Europe: the privacy artifacts — lawful basis analysis, assessments, filtering controls — are the foundation on which AI Basic Act compliance is assembled, not a separate workstream beside it.

BOARD QUESTION

Do we meet any of Korea’s domestic-representative thresholds — and if we serve Korean users at all, who has verified that our generative AI notice and labeling duties, in force since January 2026, are actually implemented in the Korean-facing product?

KEY TAKEAWAY

Korea’s fines are small and deferred; its regime is neither. The duties are in force, the reach is extraterritorial, the regulator has a documented record of remedies that reach models and data, and for the Korean market AI governance is now a condition of entry.

SOURCES AND VERIFICATION

Korean subordinate notifications and guidelines continue to be refined; verify the operative texts and current MSIT and PIPC guidance before relying on any entry. Facts verified as of August 2026.

- Act No. 20676 (AI Basic Act) and Presidential Decree No. 36053 (Enforcement Decree), both in force January 22, 2026
- Enforcement Decree provisions on: generative AI advance-notice and labeling duties; the high-performance AI compute threshold of 10^{26} cumulative FLOPs; and domestic-representative designation thresholds (including one trillion won total prior-year revenue, ten billion won AI-service revenue, or one million average daily Korean users over three months)
- High-impact AI domains including employment, healthcare, financial services, public safety, and education, with lifecycle risk management, impact assessment, and compliance duties
- MSIT enforcement posture: administrative fines capped at 30 million won; grace period of at least one year deferring investigations and fines except in exceptional cases involving serious social harm (e.g., loss of life or human-rights violations)
- Personal Information Protection Act (PIPA), including privacy-officer designation; PIPC guidelines addressed to generative AI development and deployment; PIPC corrective orders in the Scatter Lab matter (April 2021)

◆ ◆ ◆

CHAPTER 9

One Program, Three Regimes

The decision this chapter supports. Whether to run jurisdiction-specific compliance programs or one integrated program mapped to all three regimes. This chapter argues — and shows — that the second is both cheaper and safer.

In this chapter. The structural comparison across the EU, the US, and Korea; where the regimes converge and where they genuinely diverge; and the five design rules for a single global program.

9.1 The comparison

	EUROPEAN UNION	UNITED STATES	KOREA
Model	Comprehensive horizontal statute (AI Act) atop mature data protection law (GDPR)	No federal AI statute; agency enforcement under existing law plus a shifting state layer, now under federal preemption pressure	Comprehensive horizontal statute (AI Basic Act) atop strengthened privacy law (PIPA)
Risk vocabulary	Prohibited / high-risk / transparency / minimal	“Consequential decisions” and ADMT in state law; harm-based theories federally	High-impact / generative / high-performance
Transparency & labeling	Art. 50: interaction disclosure and machine-readable content marking, from Aug 2, 2026	California SB 942 detection tools and provenance (Aug 2, 2026); state disclosure duties (UT, IL, NYC, CO from 2027)	Generative AI advance notice and labeling, in force since Jan 22, 2026
High-stakes uses	Annex III regime: risk mgmt, data governance, oversight, conformity — from Dec 2, 2027 / Aug 2, 2028	Bias audits (NYC), employment discrimination liability (IL), ADMT notices and rights (CO 2027; CA CPPA 2027); ECOA/Title VII always	High-impact AI lifecycle duties — in force since Jan 22, 2026
Frontier / model layer	GPAI obligations since Aug 2025; systemic-risk tier	California SB 53 frontier framework (2026)	High-performance tier at 10^{26} FLOPs
Maximum exposure	€35M or 7% of global turnover (AI Act); €20M or 4% (GDPR)	No AI-specific cap; uncapped agency remedies, litigation, and orders that ban practices or reach systems	Fines capped at KRW 30M, deferred ≥1 year — but corrective powers and market access carry the real weight
Named accountability	Provider/deployer roles; controller accountability (Art. 5(2) GDPR)	Officer and board exposure via oversight doctrine and disclosure law (Ch. 3)	Domestic representative for larger foreign operators; PIPA privacy officer

9.2 Convergence, divergence, and the design consequence

Read down the columns and the convergence is unmistakable: every regime demands to know which systems make consequential decisions, requires people to be told when AI is involved and content to be labeled, imposes heavier lifecycle duties on high-stakes uses, reaches the frontier model layer, and names a seat of accountability. Those demands are the Know-Own-Control-Prove framework restated three times in three statutory dialects — which is why Chapter 2 built the program on the demands rather than on any one statute. The genuine divergences are narrower and manageable: timing

(Korea's high-impact duties are live now, Europe's high-risk regime lands in 2027–2028, the US state layer is in flux), penalty philosophy (European turnover-based fines versus American uncapped enforcement versus Korean forbearance-plus-corrective-power), and the American preemption fight, which has no European or Korean counterpart and requires monitoring rather than building.

Five design rules follow for the single program. **One inventory**, classified once against the strictest applicable vocabulary, with EU, US, and Korean tags derived from it rather than maintained separately. **One integrated assessment** per high-stakes system — the GDPR DPIA extended with AI Act risk-management content, Korean high-impact assessment elements, and US bias-audit evidence — completed at the deployment gate. **One transparency implementation**: design interaction disclosure and content provenance once, to the union of Article 50, SB 942, and the Korean labeling rules, and ship it globally, because maintaining jurisdiction-specific disclosure logic costs more than over-complying. **One evidence layer** serving all regulators, because a document that satisfies the most demanding inquirer satisfies the rest. And **one owner per obligation** across jurisdictions — the accountability map of Chapter 3 with three regulatory addresses, not three maps.

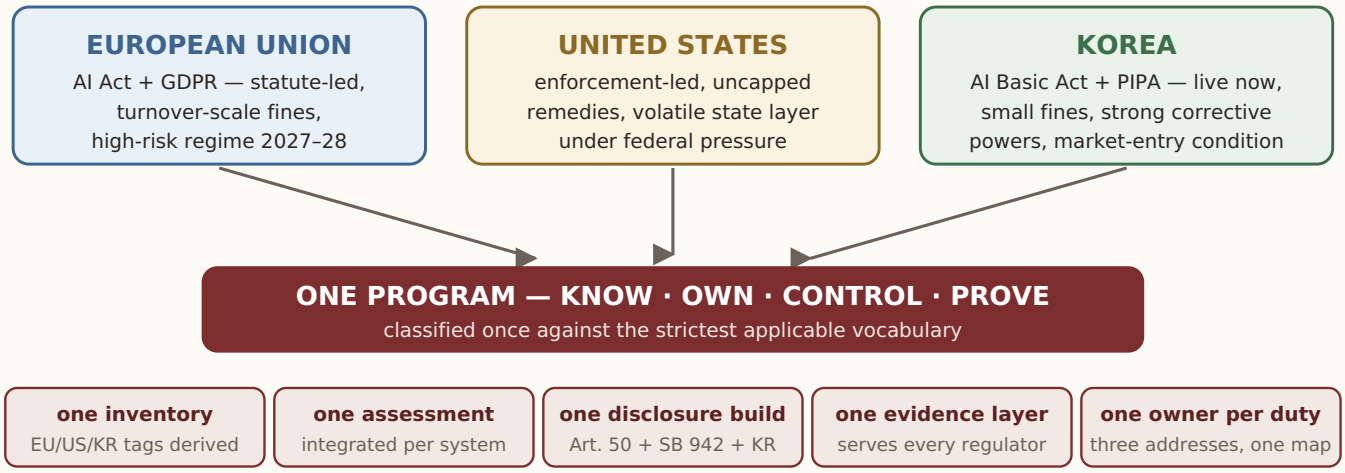


Figure 9.1. One program, three regulatory mappings. The five outputs are the design rules of Section 9.2; jurisdiction-specific work shrinks to a managed delta list on top of them.

KEY TAKEAWAY

The three regimes differ in text, timing, and temperament, and hardly at all in anatomy. Classify once against the strictest vocabulary, assess once per system, disclose once to the union of the labeling rules, file evidence once, and name one owner per obligation. Jurisdiction-specific work then shrinks to a managed delta list.

BOARD QUESTION

Are we running one AI governance program with three regulatory mappings, or three programs with three budgets — and if the latter, what would consolidation save, and who is accountable for proposing it?

SOURCES AND VERIFICATION

This chapter synthesizes the instruments verified in Chapters 4 through 8; the entries below are the primary anchors. Facts verified as of August 2026.

- Regulation (EU) 2024/1689 (EU AI Act) as amended by Regulation (EU) 2026/1744, and Regulation (EU) 2016/679 (GDPR)
- Executive Order, “Ensuring a National Policy Framework for Artificial Intelligence” (December 11, 2025); the state instruments listed in Chapter 7 (Texas HB 149; California AB 2013, SB 53, SB 942 as amended by AB 853, and CPPA ADMT regulations; Colorado SB 26-189; Illinois HB 3773; NYC Local Law 144; Utah SB 149 as amended)
- Act No. 20676 (Korea AI Basic Act) and Presidential Decree No. 36053; Personal Information Protection Act (PIPA)
- The five design rules in Section 9.2 are the author’s synthesis, offered as planning constructs rather than as measured research findings

---

End of Part II · Part III — Building the Function — begins with Chapter 10: The Business Case and Governance ROI.

PART III

BUILDING THE FUNCTION

The budget case, the organizational design, the twelve-month build, and the third-party AI risk that arrives with every vendor contract.

CHAPTER 10

The Business Case and Governance ROI

The decision this chapter supports. Whether and how much to invest in AI governance, argued the way a board expects an investment to be argued: what it costs, what it avoids, and what it returns.

In this chapter. The structure of the governance cost (bounded, front-loaded, capitalizable) against the structure of failure cost (unplanned, concentrated, compounding); the three affirmative value mechanisms; and the metrics that let the board hold the investment accountable.

10.1 The shape of the two costs

The case for AI governance is not a claim that disaster is certain; it is a claim about the shape of two cost curves. The governance investment is **bounded and front-loaded**: an inventory and classification exercise; a small central function with named owners; assessment, testing, and gating processes proportionate to risk tiers; an evidence repository; and the recurring cost of running them. Once built, the marginal cost of governing each additional AI system falls — the second DPIA reuses the first's structure, the tenth gate review takes a fraction of the first's time, and the transparency implementation of Chapter 9 ships globally once. Governance is, in accounting terms, an investment that capitalizes into every subsequent deployment.

Failure cost has the opposite shape: **unplanned, concentrated, and compounding**. Chapter 1's documented record supplies the anchors — a €1.2 billion data protection fine at the ceiling, an $89 million consumer finance order in the middle range, and settlements in the hundreds of thousands at the floor — but the direct penalty is rarely the largest line. Around it accrete litigation and settlement costs; remediation performed under regulatory supervision and deadline; the operational cost of systems withdrawn from production (the FTC's Rite Aid order banned a deployed technology for five years; Korea's PIPC has reached models and data); the commercial cost of failed procurement diligence; and management attention, the least measured and most expensive input of all. Named research ties the two curves together at the security seam: IBM's Cost of a Data Breach Report 2025 found breaches involving ungoverned "shadow AI" carried materially higher costs than average, with affected organizations disproportionately lacking basic AI access controls and governance policies — a measured link between the absence of the bounded cost and the size of the unbounded one.

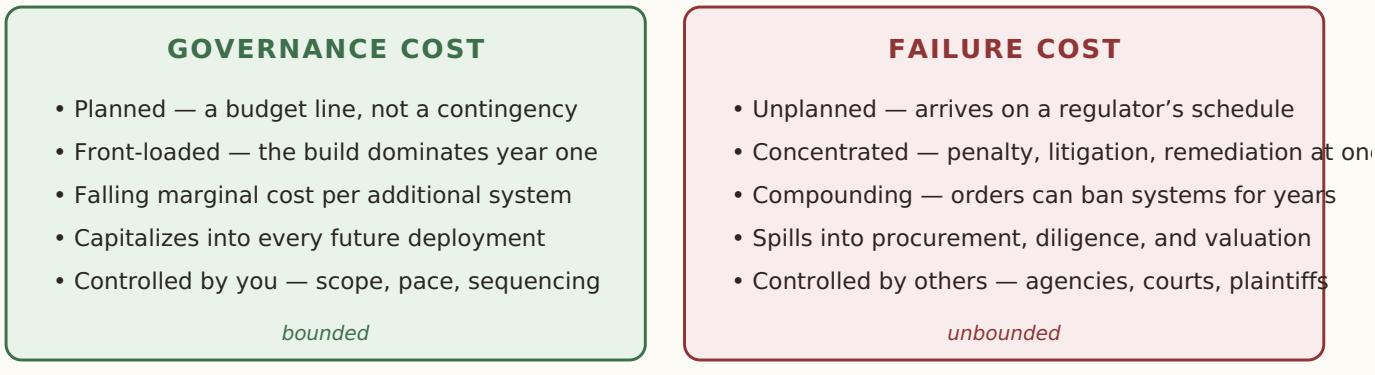


Figure 10.1. The structural asymmetry. The comparison is qualitative by design: the failure column's anchors are the documented cases of Chapter 1, not a modeled multiplier.

10.2 The three value mechanisms

The affirmative return arrives through three mechanisms introduced in Chapter 1 and now specified for budgeting. **Procurement velocity**: AI governance questionnaires are a standard component of enterprise B2B diligence, and the organization that answers from a standing evidence layer closes what the organization that scrambles delays or loses; the value is measurable as sales-cycle time and diligence pass rate on deals where AI governance was assessed. **Deployment velocity**: a functioning classification and gate process is what allows an organization to say yes to low-risk AI quickly — the alternative postures, blanket freeze and blanket approval, are both losses, one of opportunity and one of control; the value is measurable as time-to-approval by risk tier and the share of proposals resolved at the fast track. **Enterprise value**: AI governance has entered M&A and investment diligence, and the ability to produce the inventory, classifications, and assessment records on request functions the way security certification came to function — as a discount-remover; the value is realized episodically but underwritten continuously.

A planning note in the spirit of this book's method: the mechanisms above are directionally supported by the documented rise of governance questionnaires and diligence practice, but any specific percentage attached to them in a budget deck — "governance shortens sales cycles by X" — is a practitioner planning assumption unless your own pipeline data produced it. Say so on the slide. Boards trust the honest version longer.

10.3 Metrics the board can hold

DIMENSION	METRIC	WHAT IT EVIDENCES
Know	Inventory coverage: systems registered vs. discovered in procurement/technical sweeps; % classified; days since last verification	The estate is counted and current
Own	% of systems and obligations with a named owner; owner review completion rate	Accountability is individual, not diffuse
Control	Gate pass/block/conditional rates by tier; median time-to-approval by tier; testing and monitoring completion on schedule	Governance operates as a precondition, and doesn't strangle low-risk work
Prove	% of required artifacts filed at generation; time to answer a standard diligence questionnaire; audit findings open/closed	Evidence exists before the question arrives
Outcome	AI incidents by severity; regulatory inquiries and their disposition; diligence outcomes on AI-assessed deals	The program is changing results, not producing paper

BOARD QUESTION

What did we spend on AI governance last year, what would the metrics table above show if produced today, and which single metric does management propose the board track quarterly?

KEY TAKEAWAY

Fund governance as an investment with falling marginal cost and three measurable value mechanisms — and present the avoided-cost side with the documented record, not invented multipliers. The honest version of this business case is also the strongest one.

SOURCES AND VERIFICATION

Facts verified as of August 2026. Quantitative figures are either attributed to the named research that produced them or expressly identified as planning constructs; the two are never blended.

- IBM, Cost of a Data Breach Report 2025 (elevated breach costs involving shadow AI; prevalence of missing AI access controls and governance policies among affected organizations)
- Stanford University Institute for Human-Centered AI, AI Index Report (rising documented AI incident counts alongside accelerating legislative activity)
- McKinsey & Company, Global Survey on AI (sustained majority-level and growing organizational AI adoption)
- Documented enforcement anchors as cited in Chapter 1 (Meta €1.2B; CFPB $89M+; FTC Rite Aid order; PIPC Scatter Lab; EEOC iTutorGroup; SEC AI-washing penalties)
- The metrics table (10.3), the value-mechanism framing (10.2), and Figure 10.1 are the author’s synthesis, offered as planning constructs rather than measured research findings

◆ ◆ ◆

CHAPTER 11

Organizational Design

The decision this chapter supports. How to structure the people side of governance — the executive sponsor, the functional owners, and the committee — sized to the organization you actually run, not the one in the diagram.

In this chapter. The three-tier ownership model made operational; the Chief AI Officer question answered by size and exposure rather than fashion; what the governance committee is for once ownership is individual; and the failure patterns of each design.

11.1 The three tiers, staffed

Chapter 3 established the accountability map; this chapter staffs it. The **executive sponsor** owns the program — inventory, classification methodology, gate criteria, evidence layer, and reporting — with budget authority and direct board access. The **functional owners** own the recurring obligations inside their disciplines: legal owns regulatory interpretation and the delta lists of Chapter 9; privacy owns the integrated assessment and the data protection artifacts; engineering owns testing, monitoring, and the technical half of every gate; security owns the AI threat surface and incident response; compliance owns audit readiness and the evidence layer's integrity. The **system owners of record** — product and business-line leaders — own each inventory entry's classification being current and its controls being live. The design rule that makes the model work is that each tier's ownership appears in written charters and performance objectives; the design rule that makes it affordable is that only the first tier is a new role, and often not even that.

11.2 The Chief AI Officer question

Whether to create a dedicated Chief AI Officer is a sizing decision, not a signaling one. The honest determinants are exposure and scale: the number of high-stakes systems in the inventory, presence in all three regimes of Part II, whether the organization provides AI (carrying provider duties) or only deploys it, and whether any single existing executive has the standing to halt a launch. Three workable patterns cover most organizations.



Figure 11.1. Three sponsor patterns by size and exposure. Moving right adds capacity and authority; the failure mode of each pattern is noted at its base, because that is what the design must engineer against.

11.3 What the committee is for

Once ownership is individual, the cross-functional AI governance committee acquires a real job — three of them. It is the **coordination surface** where owners surface conflicts and dependencies: privacy's assessment finding meets engineering's release date meets legal's delta list, in one room instead of six email threads. It is the **escalation path** for the cases the tiered gates cannot resolve — novel use cases, borderline classifications, conflicts between a business unit and an owner — with the sponsor holding the deciding vote and the record showing the reasoning. And it is the **calibration mechanism** that reviews gate criteria, thresholds, and the maturity self-assessment on a defined cycle so the program tightens where incidents occurred and loosens where friction produced no risk reduction. What the committee is not for is owning anything: the moment a decision is attributed to "the committee," Chapter 2's failure pattern has arrived, and the minutes should be read to find the person who should have owned it.

COMMON FAILURE PATTERN

The prestige committee: senior names, quarterly meetings, no connection to the deployment pipeline. Its tell is that launches never wait for it. If the governance body can be bypassed without consequence, the organization has a discussion group, and its minutes will read very differently to a regulator than to its members.

BOARD QUESTION

Who in this organization has actually stopped or conditioned an AI launch in the last twelve months — and if the answer is no one, is that because every system was ready, or because no one has the authority?

SOURCES AND VERIFICATION

Facts verified as of August 2026.

- Regulatory anchors for named accountability as established in Chapters 3 and 8: GDPR Article 5(2); EU AI Act provider/deployer role architecture and Article 26; Korea's domestic-representative mechanism and PIPA privacy-officer designation
- ISO/IEC 42001:2023 (AI management systems) and NIST AI RMF 1.0 (Govern function), whose organizational-role expectations parallel the three-tier model
- The three-tier staffing model, the sponsor patterns of Figure 11.1, and the committee design of 11.3 are the author's synthesis, offered as planning constructs rather than measured research findings

◆ ◆ ◆

CHAPTER 12

The Twelve-Month Roadmap

The decision this chapter supports. How to sequence the build from wherever the organization honestly is — usually Maturity Level 1 to 2 — to an operating program at Level 3, inside twelve months and ahead of the regulatory dates that matter.

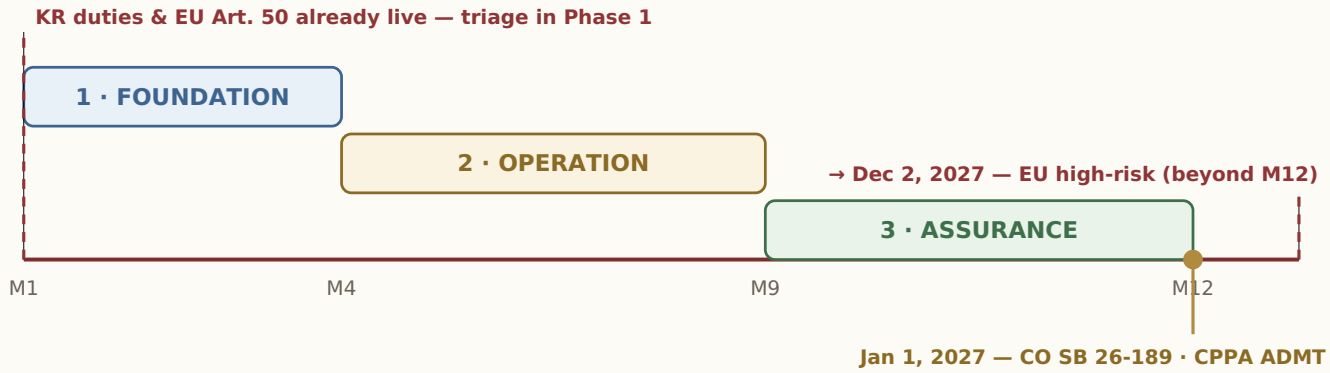
In this chapter. Three phases — Foundation, Operation, Assurance — with the deliverable, owner, and exit criterion of each; the external calendar the roadmap must beat; and the two places twelve-month plans actually die.

12.1 The external calendar the plan must beat

A roadmap starting in late 2026 runs against fixed external dates: Korea's AI Basic Act duties and the EU's Article 50 transparency duties are *already live*, so the transparency workstream is remediation, not preparation, and belongs in the first phase; January 1, 2027 brings Colorado's SB 26-189 ADMT disclosure regime and California's CPPA ADMT notice and opt-out provisions, plus SB 942's hosting-platform duties; and December 2, 2027 lands the EU high-risk regime for Annex III systems, with August 2, 2028 following for product-embedded AI. A twelve-month build that completes in late 2027 therefore arrives with roughly the right timing — provided it starts now and provided the already-live duties are triaged first rather than queued politely behind the inventory.

12.2 The three phases

PHASE	DELIVERABLES	EXIT CRITERION
1 · FOUNDATION months 1–3	Inventory built from procurement, contracts, and technical discovery; two-axis classification; owners named in charters; committee chartered; *live-duty triage* — Korean generative-AI notices and EU Article 50 disclosure verified in production for in-scope products	The register exists, every entry has an owner, and no already-applicable transparency duty is unmet for a known system
2 · OPERATION months 4–8	Deployment gates enforced by tier; integrated assessment template (DPIA + AI Act + Korean high-impact elements) run on every high-stakes system; testing and human-oversight designs completed for the top of the pyramid; monitoring and incident-response paths stood up; vendor terms remediation begun (Ch. 13)	No system reaches production without passing its gate, and the highest-risk systems each hold a completed assessment with evidence filed
3 · ASSURANCE months 9–12	Internal audit or independent review of the program; board reporting cadence and metrics (Ch. 10) live; maturity self-assessment with documentary support; 2027 regulatory-date readiness check (CO/CPPA in month ~12; EU high-risk workplan through Dec 2027)	The board has received two reporting cycles, an independent set of eyes has tested the program, and the 2027 dates have owners and dated plans



Phases overlap by design: gates begin while the inventory tail is still being classified.

Figure 12.1. The twelve-month build against the external calendar for a program starting in late 2026. The already-live duties enter at month one; the 2027 dates fall at and beyond the plan's edge, with owners assigned in Phase 3.

12.3 Where twelve-month plans die

Two places, reliably. The first is **the inventory that never finishes** — the perfectionist trap of refusing to start Phase 2 until every embedded AI feature in every SaaS contract is catalogued. The countermeasure is a materiality rule set on day one: the inventory is "done enough" when the systems touching consequential decisions, customers, and regulated data are registered and classified; the long tail is a standing discovery process, not a phase gate. The second is **the gate that exists but does not bind** — announced in month five, bypassed by a flagship launch in month six, dead by month seven. The countermeasure is political, not procedural: the first contested gate decision is the moment the program becomes real, which is why the sponsor's halt authority (Chapter 11) must be settled before Phase 2 begins, not negotiated during the first conflict.

KEY TAKEAWAY

Triage the already-live duties in month one, run Foundation–Operation–Assurance with exit criteria rather than dates alone, cap the inventory with a materiality rule, and settle halt authority before the first contested launch. Twelve months from a Level 1–2 start, the program should be operating — with 2027's deadlines owned, not discovered.

BOARD QUESTION

Which phase is the program in today, what is the exit criterion it has not yet met, and what date has management committed to for meeting it?

SOURCES AND VERIFICATION

Facts verified as of August 2026.

- External calendar anchors as verified in Part II: Korea AI Basic Act duties in force January 22, 2026; EU AI Act Article 50 duties from August 2, 2026; Colorado SB 26-189 and California CPPA ADMT provisions (and SB 942 hosting-platform duties) from January 1, 2027; EU Annex III high-risk obligations from December 2, 2027 and Annex I from August 2, 2028
- The three-phase structure, exit criteria, and failure-point analysis are the author’s synthesis, offered as planning constructs rather than measured research findings

CHAPTER 13

Vendors and Third-Party AI

The decision this chapter supports. How to govern the AI the organization did not build — which, for most enterprises, is most of the AI it runs — through diligence, contract, and lifecycle management rather than hope.

In this chapter. Why “we just buy it” is not a defense in any of the three regimes; the role-shift trap that turns deployers into providers; the contract clauses that matter; and the vendor lifecycle from diligence to exit.

13.1 Buying is not outsourcing the risk

Every regime of Part II reaches the buyer. Under the EU AI Act, deployers of high-risk systems carry their own Article 26 duties — competent human oversight, use per instructions, monitoring, log retention — and a deployer that substantially modifies a system or markets it under its own name can become a provider with the full provider stack. Under the GDPR, the controller’s accountability does not transfer to a processor, and the controller answers for the vendor’s processing it directs. In the United States, the EEOC’s position and the *Mobley v. Workday* litigation frame the employment version — the algorithm’s screening decision is the employer’s decision, while the vendor may be reachable too, which protects no buyer — and the FTC holds companies responsible for the claims their AI-powered products make regardless of whose model sits underneath. Korea’s AI Basic Act attaches its duties to the operator offering the AI product or service in the market, wherever the underlying model came from. Across all three regimes the pattern is identical: the law follows the deployment, not the invoice.

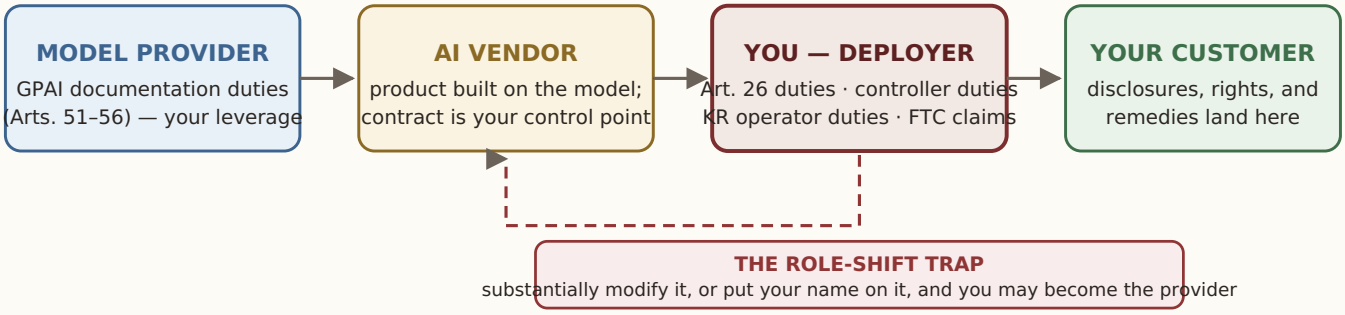


Figure 13.1. The AI supply chain. Your statutory duties sit at the deployer box regardless of what you bought; your contract with the vendor is where you acquire the documentation and rights needed to discharge them.

13.2 Diligence before contract

Vendor diligence is the Know commitment applied outward, and it is cheap relative to what it prevents. The questions that separate governed vendors from fluent ones are evidentiary: show the model documentation and, for general-purpose models, the Article 51–56 artifacts or Code of Practice adherence; show bias and performance testing relevant to our use case, not a generic fairness statement; show the training-data lawful-basis position (the Chapter 5 question — vendors who cannot answer it transfer its risk to you); show certifications with scope — ISO/IEC 42001 or SOC 2 with the AI systems

actually in scope, since a certificate covering the corporate website governs nothing; and show the incident history and notification commitments. A vendor's refusal to answer is itself an answer, and the diligence file — kept, dated, and owned — is Prove-layer evidence that the organization exercised care in selection, which is exactly what a regulator or plaintiff will later ask.

13.3 The clauses that matter

CLAUSE	WHAT IT MUST SECURE
Documentation & cooperation	Delivery and maintenance of the technical documentation, instructions for use, and information you need to meet your deployer, controller, and Korean operator duties — including cooperation with your assessments, audits, and regulator inquiries
Data use & training rights	Whether the vendor may use your data (or your customers' data) to train or improve models — default no, with any exception explicit, scoped, and reversible
Transparency pass-through	The technical facts you need to meet Article 50, SB 942, and Korean labeling duties: what is generated, how it is marked, and how provenance survives your pipeline
Performance, bias & testing	Committed accuracy and testing representations for your use case; your right to test and to receive updated results when the model materially changes
Change notice	Advance notice of model swaps, retraining, and material behavior changes — the silent model update is the vendor-risk event that monitoring alone catches too late
Incidents & support	Defined incident notification windows and cooperation duties aligned to your regulatory clocks, not the vendor's convenience
Subprocessors & flow-down	Visibility into the vendor's own AI supply chain and flow-down of the material commitments to it
Liability & exit	Liability allocation that reflects the regulatory exposure the vendor's failures create for you; data return and deletion, transition assistance, and — where feasible — portability that keeps exit real

13.4 Lifecycle and concentration

Vendor governance does not end at signature. Each vendor system is an inventory entry with an owner, a classification, and a gate like anything built in-house; monitoring watches its behavior in your context, because the vendor's assurances were made about theirs; and the annual review re-runs the diligence questions against what the vendor has since become. Above the individual contracts sits a portfolio question the board should see once a year: **concentration**. When one model provider sits beneath many of the organization's vendor products — an increasingly common discovery once the inventory maps the supply chain rather than the invoices — a single upstream change, outage, or enforcement action propagates across the estate at once. Concentration is not automatically wrong; unexamined concentration is.

COMMON FAILURE PATTERN

Governing the vendor list instead of the vendor systems. The procurement file says the relationship was approved in 2025; the model underneath has been swapped twice since, the use case has expanded from drafting to decisions, and no gate ever saw the change. Vendor governance that does not attach to the inventory and the change-notice clause is a snapshot of a moving object.

BOARD QUESTION

Which single upstream AI provider are we most concentrated on across our vendor portfolio — and what is the plan if that provider has a Rite Aid-scale enforcement event, a breaking model change, or an outage next quarter?

SOURCES AND VERIFICATION

Facts verified as of August 2026.

- Regulation (EU) 2024/1689 (EU AI Act): Article 26 (deployer obligations), Article 25 (circumstances in which a distributor, importer, deployer, or other third party is considered a provider), Articles 51–56 (general-purpose AI documentation)
- Regulation (EU) 2016/679 (GDPR): Articles 24 and 28 (controller responsibility and processor contracts)
- *Mobley v. Workday, Inc.* (N.D. Cal.) and EEOC enforcement posture on employer responsibility for algorithmic screening (iTutorGroup, 2023)
- Federal Trade Commission enforcement holding companies responsible for AI product claims and deployments (Rite Aid order, 2023; Operation AI Comply, 2024)
- Act No. 20676 (Korea AI Basic Act): duties attaching to operators offering AI products or services affecting the Korean market
- ISO/IEC 42001:2023 and SOC 2 as scope-dependent assurance mechanisms referenced in diligence
- The clause table (13.3) and lifecycle design (13.4) are the author’s synthesis, offered as planning constructs and drafting checklists rather than legal advice

End of Part III · Part IV — Decisions — begins with Chapter 14: Three Decisions You Will Face.

PART IV

DECISIONS

The three decisions every executive team will face, and the standing agenda that keeps the board demonstrably watching.

CHAPTER 14

Three Decisions You Will Face

The decision this chapter supports. All three of them. Enterprise AI governance ultimately compresses into three recurring executive decisions — adopting generative AI broadly, approving a high-stakes use, and responding to an incident — and each has a playbook that can be written before the pressure arrives.

In this chapter. Each decision as a gate: the question actually being decided, what the three regimes attach to it, the checklist that must be satisfied, and the way the decision usually goes wrong.

14.1 Decision one: adopting generative AI across the enterprise

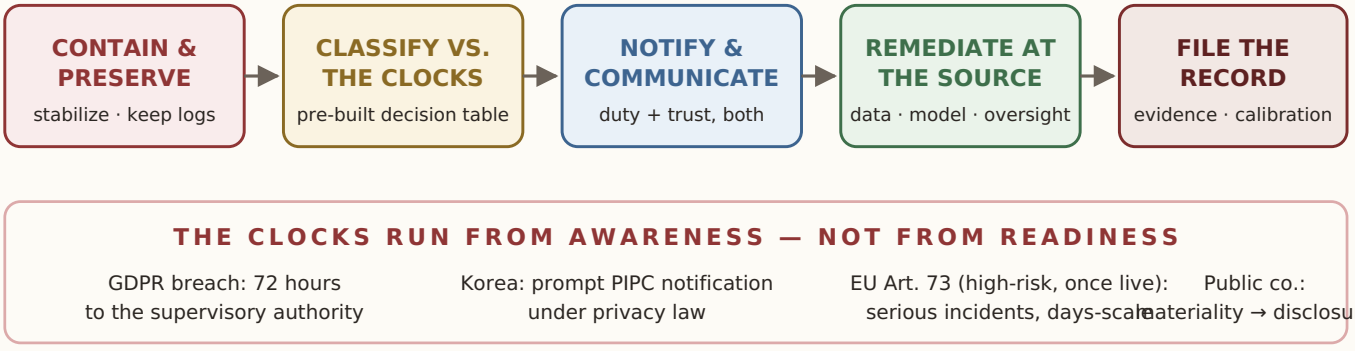
The question being decided is not “do we allow generative AI” — employees are already using it, sanctioned or not, which is why IBM’s 2025 findings on ungoverned shadow AI belong in this discussion — but “on what terms do we convert unmanaged use into managed capability.” The regimes attach real duties the moment generative AI touches customers or content: Korea’s advance-notice and labeling rules have applied since January 2026, the EU’s Article 50 interaction-disclosure and content-marking duties since August 2026, and California’s SB 942 provenance regime for covered providers since the same month; behind them sit the training-data and confidentiality questions of Chapters 5 and 13. The playbook therefore has four moves: **sanction and channel** — approve specific tools through the gate so the unsanctioned ones can be genuinely restricted; **contract for the risks** — the data-use, training-rights, and transparency pass-through clauses of Chapter 13; **ship the disclosure layer once**, to the union of the three regimes, as Chapter 9 prescribed; and **set use-case boundaries by tier** — drafting assistance is minimal-risk, customer-facing generation is transparency-tier, and any generative output that feeds a consequential decision graduates to the high-stakes track of the next section. The common failure is deciding this as a culture question (“innovation versus caution”) rather than a classification question; the classification answers it system by system, which is the only level at which it is actually decidable.

14.2 Decision two: approving a high-stakes use

Hiring screens, credit decisions, healthcare triage, insurance pricing, benefits eligibility: the uses that touch livelihoods are where every regime concentrates its force — the EU’s Annex III regime arriving December 2027, Korea’s high-impact duties live now, US employment and credit law enforceable since before AI existed, and the state ADMT disclosure regimes landing January 2027. The approval gate for this tier is the book’s machinery at full depth, and it must produce answers to five questions before launch, each with evidence filed: Is the **classification** confirmed against all three vocabularies, with the strictest governing? Does the **integrated assessment** exist — DPIA, AI Act risk content, Korean high-impact elements — with mitigations decided, not merely listed? Has **testing** demonstrated performance and examined disparate impact for the populations this system will actually judge, with thresholds set before the results came back? Is **human oversight** designed so the reviewer can see, change, and override — the Article 22 standard of Chapter 5 — at the volume the system will really run? And is the **adverse-outcome path** built: the notice, the explanation, the contest mechanism that ECOA has required of credit for decades and the ADMT regimes now generalize? A “no” or “not yet” on any of the five is the gate doing its job. The common failure is approving the pilot casually and letting scale arrive without a second look — the system that was tolerable at 200 decisions a year is a different risk at 200,000, and the gate must re-trigger on scale, scope, and model change, not only on launch.

14.3 Decision three: responding to an AI incident

The incident will be one of a small number of shapes — a discriminatory-outcome discovery, a hallucination or generation harm that reached customers, a data or security event involving an AI system, or a vendor's upstream failure — and the response has a structure that can be rehearsed. What cannot be improvised are the **clocks**: a personal-data breach starts the GDPR's 72-hour notification to the supervisory authority; Korean privacy law carries its own prompt-notification duties to the PIPC; once the EU high-risk regime applies, Article 73 serious-incident reporting runs on deadlines measured in days; US state breach statutes and sector rules add their own timers; and for public companies, a materiality determination starts disclosure obligations of the kind cyber incidents made familiar. The playbook: **contain and preserve** — stabilize the system (suspend, constrain, or roll back) while preserving logs and versions, because the Prove layer is now legal evidence; **classify the incident against the clocks** — a pre-built decision table mapping incident types to notification duties, owned by legal, consulted in minutes rather than researched over a weekend; **notify what the clocks require and communicate what trust requires**, which are overlapping but not identical sets; **remediate at the source** — data, model, integration, or oversight design — rather than at the symptom; and **file the record**, because the incident's documentation is both the regulator's first request and the program's best calibration input. The common failure is organizational, not technical: treating the incident as the deploying team's problem for the first week, so that legal and the sponsor meet the clocks already half-expired.



Rehearse once a year against a hypothetical: the first real run should be the second run.

Figure 14.1. The incident sequence and the clocks beneath it. The decision table in step two is written in peacetime; the evidence preserved in step one is what every later step, and every regulator, consumes.

KEY TAKEAWAY

The three decisions share one anatomy: they are gates, decidable system-by-system against classification, assessment, testing, oversight, and evidence. Written as playbooks in peacetime, they take days; improvised under pressure, they take quarters — and the clocks in the third one do not pause for the improvisation.

BOARD QUESTION

Have the three playbooks in this chapter been written, owned, and — for the incident playbook — rehearsed in the last twelve months? Which of the three would management least like to run tomorrow?

SOURCES AND VERIFICATION

Facts verified as of August 2026.

- Transparency and labeling duties as verified in Part II: Korea AI Basic Act (from January 22, 2026); EU AI Act Article 50 (from August 2, 2026); California SB 942 (operative August 2, 2026)
- High-stakes anchors: EU AI Act Annex III regime (from December 2, 2027); Korea high-impact AI duties (in force); Colorado SB 26-189 and California CPPA ADMT provisions (from January 1, 2027); ECOA/FCRA adverse-action requirements; GDPR Article 22
- Incident clocks: GDPR Article 33 (notification to the supervisory authority without undue delay and, where feasible, within 72 hours); Korean privacy-law notification duties to the PIPC; EU AI Act Article 73 serious-incident reporting for high-risk systems; US state breach-notification statutes; public-company disclosure practice following materiality determination
- IBM, Cost of a Data Breach Report 2025 (shadow AI findings referenced in 14.1)
- The three playbooks and the five-question gate of 14.2 are the author’s synthesis, offered as planning constructs rather than legal advice

CHAPTER 15

The Board Agenda

The decision this chapter supports. What the board should ask for, how often, and in what form — so that the oversight duty of Chapter 3 is discharged on the record, and so that the questions asked shape the program that answers them.

In this chapter. The standing quarterly item and the annual deep cycle; the one-page report the board should insist on; the question bank drawn from every chapter; and the regulatory horizon to watch through 2027–2028.

15.1 The cadence

The oversight standard the courts and regulators actually apply — a reasonable information and reporting system, engaged with in good faith — is met by a modest, consistent cadence, not by heroic episodes of attention. The workable pattern is a **standing quarterly item** of fifteen minutes on a one-page report, plus an **annual deep cycle** distributing four subjects across the year: the maturity self-assessment with its documentary support (Q1); the high-stakes system portfolio and the year's gate decisions, including what was blocked or conditioned (Q2); vendor concentration and third-party risk (Q3); and the incident-playbook rehearsal readout with the regulatory-horizon review (Q4). Minutes should show the engagement — the question asked, the answer given, the follow-up assigned — because Chapter 3's doctrine ultimately tests for a record, and a record is made of exactly this.

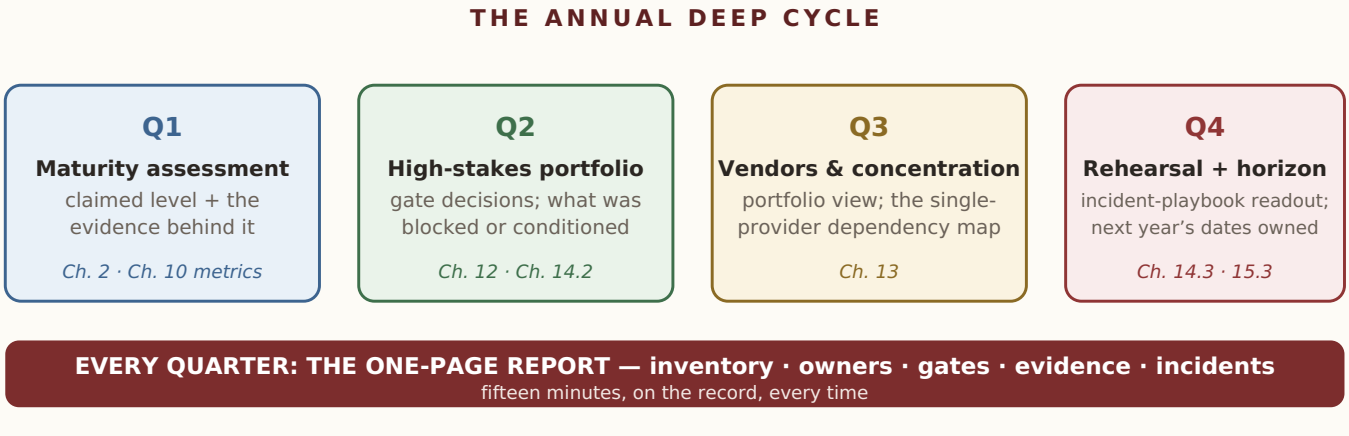


Figure 15.1. The board cadence: a standing quarterly item on a one-page report, with one deep subject per quarter. Modest, consistent, and minuted — which is precisely what the oversight doctrine of Chapter 3 tests for.

15.2 The one-page report and the question bank

The quarterly page carries five lines, one per commitment plus outcomes, drawn from the metrics table of Chapter 10: inventory coverage and freshness (**Know**); ownership completeness (**Own**); gate volumes, decisions, and time-to-approval by tier (**Control**); evidence filing rate and diligence-response time (**Prove**); and incidents, inquiries, and their disposition (**Outcomes**). Around the page, the board's craft is the question — and this book has been building the bank of them all along: the thirteen Board Question callouts of Chapters 1 through 14 are designed to be asked verbatim, from "who owns

our highest-risk system, in writing” (Ch. 3) to “who has actually stopped a launch” (Ch. 11) to “which upstream provider are we most concentrated on” (Ch. 13). A board that rotates through the bank across a year will have tested every load-bearing wall of the program, and the minutes will show it.

15.3 The horizon through 2028

WHEN	WHAT ARRIVES	WHAT THE BOARD SHOULD SEE BEFOREHAND
Late 2026	Korea’s fine-deferral grace period approaches its first anniversary (January 2027); EU watermarking and NCII/CSAM technical-safeguard grace periods run to December 2, 2026	Confirmation that Korean-market duties and EU content-marking are implemented, not merely planned
Jan 1, 2027	Colorado SB 26-189 ADMT regime; California CPPA ADMT notices and opt-outs; SB 942 hosting-platform duties	The US disclosure build tested against real product flows, with the delta list closed
Through 2027	The US preemption litigation matures; state legislatures respond; EU harmonized standards for high-risk systems progress toward publication	A monitoring brief, not a build: scenarios, not panic
Dec 2, 2027	EU Annex III high-risk obligations apply	Conformity readiness per system: assessment, testing, oversight design, documentation — evidence sighted by the board in Q2–Q3 2027
Aug 2, 2028	EU Annex I product-embedded high-risk obligations apply	The product-line inventory mapped to Annex I, with owners and dated plans

KEY TAKEAWAY

Board oversight of AI is a cadence, a page, and a question bank — kept on the record. The horizon through 2028 is known and dated; a board that has sighted the evidence one quarter before each date has done its job, and can prove it.

BOARD QUESTION

The last one in the bank: if everything in this book stopped tomorrow — the sponsor left, the committee dissolved — how long before the organization’s AI estate was effectively ungoverned again? If the honest answer is “immediately,” the program is a person, not a system; the goal of everything above is that the answer be “not for a long time.”

SOURCES AND VERIFICATION

Facts verified as of August 2026.

- Oversight-doctrine anchors as cited in Chapter 3 (*Caremark*; *Marchand v. Barnhill*)
- Horizon dates as verified in Part II: Korea AI Basic Act grace-period timing; Regulation (EU) 2026/1744 grace periods to December 2, 2026 and high-risk dates of December 2, 2027 and August 2, 2028; Colorado SB 26-189 and California CPPA/SB 942 dates of January 1, 2027
- The cadence design, one-page report, and question bank are the author’s synthesis, offered as planning constructs

APPENDICES

THE REFERENCE PAGES

The three regimes at a glance, and the implementation checklist — built for the desk, not the shelf.

APPENDIX A

The Three Regimes at a Glance

Status as of August 2026. Every date and figure below is treated in full, with sources, in the chapter indicated; verify the operative text before relying on any entry.

	EUROPEAN UNION	UNITED STATES	KOREA
Primary instruments	AI Act (Reg. 2024/1689, as amended by Reg. 2026/1744); GDPR (Reg. 2016/679) — Ch. 4–5	No federal AI act; FTC/CFPB/EEOC/SEC enforcement + state statutes — Ch. 6–7	AI Basic Act (Act No. 20676) + Enforcement Decree; PIPA — Ch. 8
In force today	Prohibitions & AI literacy (Feb 2, 2025); GPAI duties (Aug 2, 2025); general application & Art. 50 transparency (Aug 2, 2026)	All agency enforcement; TX TRAIGA, CA AB 2013 & SB 53, IL HB 3773 (Jan 1, 2026); CA SB 942 (Aug 2, 2026); NYC LL144 (2023); UT (2024–25)	Entire Act and Decree (Jan 22, 2026): generative-AI notice/labeling, high-impact duties, high-performance tier, domestic representative
Arriving next	Watermarking/NCII-CSAM safeguard grace ends Dec 2, 2026; Annex III high-risk Dec 2, 2027; Annex I Aug 2, 2028	CO SB 26-189 & CPPA ADMT rights, SB 942 hosting duties (Jan 1, 2027); preemption litigation ongoing	Fine-deferral grace period reaches one year Jan 2027; subordinate guidelines continue to issue
Risk vocabulary	Prohibited / high-risk / transparency / minimal	Consequential decisions · ADMT · prohibited uses	Generative / high-impact / high-performance (10^{26} FLOPs)
Maximum exposure	€35M or 7% of global turnover (AI Act); €20M or 4% (GDPR)	No cap: agency remedies, litigation, practice bans (e.g., 5-year Rite Aid order)	Fines capped KRW 30M, deferred ≥1 yr — corrective powers and market access carry the weight
Accountability seat	Provider/deployer roles; controller accountability (Art. 5(2))	Board oversight doctrine; officer disclosure exposure	Domestic representative (thresholds: KRW 1T revenue / KRW 10B AI revenue / 1M daily users); PIPA privacy officer
Program consequence	One inventory · one integrated assessment · one disclosure build · one evidence layer · one owner per obligation — Ch. 9		

◆ ◆ ◆

APPENDIX B

The Implementation Checklist

The twelve-month roadmap of Chapter 12 as a checkable artifact. An item is complete when its evidence is filed — not when its meeting has been held.

Phase 1 · Foundation (months 1–3)

- ☐ AI inventory built from procurement records, vendor contracts, and technical discovery — built, bought, and embedded systems — with a materiality rule set on day one (Ch. 2, 12)
- ☐ Every registered system classified on two axes: legal risk tier (strictest applicable vocabulary) and business criticality (Ch. 2, 9)
- ☐ Executive sponsor appointed with written halt authority; functional owners and system owners named in charters and objectives (Ch. 3, 11)
- ☐ Governance committee chartered: coordination, escalation, calibration — no ownership (Ch. 11)
- ☐ Live-duty triage complete: Korean generative-AI notice/labeling and EU Article 50 disclosure verified in production for all in-scope products (Ch. 8, 4, 12)
- ☐ Evidence repository established with filing conventions and retention schedule (Ch. 2)

Phase 2 · Operation (months 4–8)

- ☐ Deployment gates enforced by tier, with criteria published and the first contested decision decided and minuted (Ch. 2, 12)
- ☐ Integrated assessment template in use — DPIA + AI Act risk content + Korean high-impact elements — completed for every high-stakes system (Ch. 5, 9)
- ☐ Bias and performance testing run against pre-set thresholds for the top of the risk pyramid; human-oversight designs meeting the see-change-override standard (Ch. 14.2, 5)
- ☐ Production monitoring and the incident decision table (incident types → notification clocks) stood up and owned by legal (Ch. 14.3)
- ☐ Vendor remediation begun: diligence files, the eight clause categories in new and renewing contracts, model-change notice secured (Ch. 13)
- ☐ Domestic-representative analysis for Korea completed and, where thresholds are met, the designation made (Ch. 8)

Phase 3 · Assurance (months 9–12)

- ☐ Independent or internal-audit review of the program completed; findings owned and dated (Ch. 12)
- ☐ Board cadence live: one-page quarterly report delivered twice; annual deep cycle scheduled (Ch. 15)
- ☐ Maturity self-assessment produced with documentary support — a claimed level without evidence is Level 1 (Ch. 2)
- ☐ Incident playbook rehearsed against a hypothetical; readout delivered to the board (Ch. 14.3, 15)
- ☐ 2027 readiness owned: January 2027 US disclosure duties tested against product flows; December 2027 EU high-risk workplan per system, with owners and dates (Ch. 12, 15)
- ☐ Vendor concentration map presented to the board with the single-provider contingency answered (Ch. 13, 15)

KEY TAKEAWAY

Twenty items, three phases, one test throughout: is the evidence filed? An organization that can check this list honestly is operating at Maturity Level 3 — governed, demonstrable, and ready for the dates on the horizon.

End of the book · The Executive's Guide to Global AI Governance · First Edition, 2026
Coverage current through August 2026 — verify the operative texts before relying on any entry.

THE EXECUTIVE'S GUIDE TO

GLOBAL AI GOVERNANCE

A board-level reference for responsible, defensible, and operational AI governance across jurisdictions.

✦ ✦ ✦

“

AI Governance: Now Is the Time to Act.

Built for executive review, investment decisions, and governance accountability — with a visual identity aligned to the front cover's black and gold palette.

WOONGSIK SU

FIRST EDITION · 2026